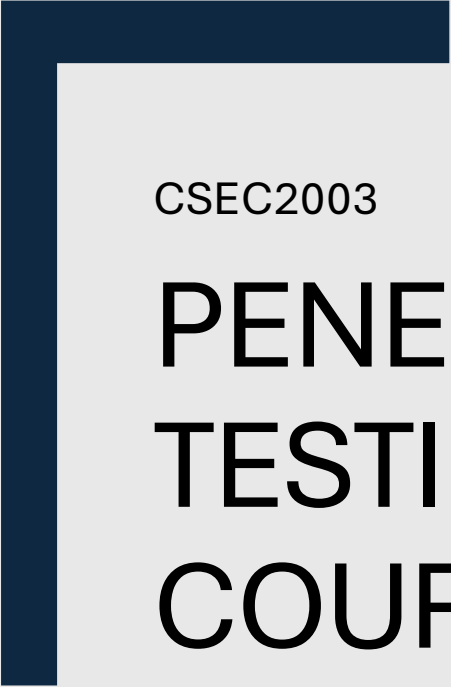




CSEC2003

PENETRATION TESTING COURSEWORK

Hayden Manley

P2860912



CONTENTS

1.0 Executive Summary	1
1.1 Overview of the Assessment.....	1
1.2 Summary of Findings	2
1.3 Business Impact	2
1.4 Overall Risk Level.....	2
.....	3
1.5 Recommendations	3
Technical Summary	4
2.1 Scope and Methodology.....	4
2.2 Vulnerability Overview and Recommendations	4
2.3 Risk Analysis	8
4 Scope	9
5. Rules of Engagement	9
3.Assessment Summary.....	10
6. OWASP Methodology	10
6.1 Information gathering (WSTG- INFO).....	10
6.2 Configuration and Deployment Management Testing (WSTG-CONF)	18
6.3 Identity Management Testing (WSTG-ID)	21
6.4 Authentication Testing (WSTG-ATHN) (WSTG- ATHZ)	22
6.5 Authentication Testing (WSTG-ATHN) (WSTG- ATHZ)	24
6.6 Session Management Testing (WSTG-SESS)	24
6.7 input Validation Testing (WSTG-INPV).....	27
6.8 Testing for Error Handling (WSTG-ERR)	44
6.9 Testing for Weak Cryptography (WSTG-CRYP)	45
6.10 Business Logic Testing (WSTG-BUSL).....	45
6.11 Client-Side Testing (WSTG-CLNT)	45
6.12 API Testing (WSTGAP).....	46
7.0 Social Engineering Phishing Email	47
7.1 References.....	54

1.0 Executive Summary

1.1 OVERVIEW OF THE ASSESSMENT

I conducted a Penetration test on the BadStore web application to evaluate its overall position in terms of security I was able to identify potentially weaknesses that could be exploited by attackers. The assessment focused on publicly accessible web services and followed a structured and industry-recognised testing methodology called OWASP.

DO NOT COPY

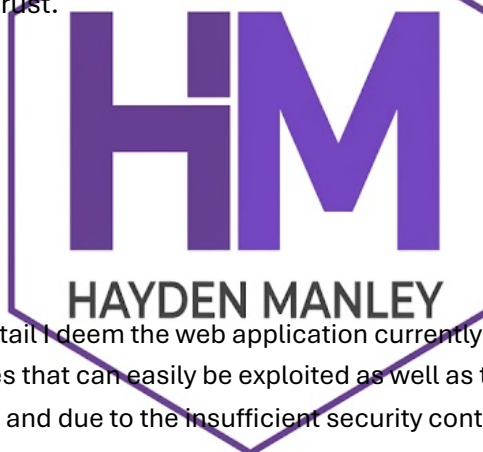
1.2 SUMMARY OF FINDINGS

The assessment identified several security weaknesses these include issues related to how user input is handled, weaknesses in session security and exposure of sensitive information. The weaknesses increase the likelihood of unauthorised access and misuse of the system if exploited by malicious attackers.

1.3 BUSINESS IMPACT

The vulnerabilities I have discovered in this test if exploited could have numerous impacts on the business some with great severity. Exploitation of the vulnerabilities could result in

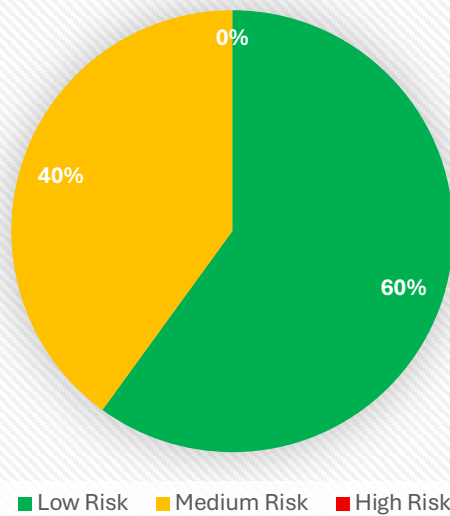
- Unauthorised access to user and supplier accounts
- Exposure of sensitive customer and business data
- Increased risk of targeted phishing attacks against suppliers
- Reputational damage and loss of customer trust
- Financial loss in many ways such as Legal fees ransom payments downtime and profit loss through loss of customers due to lack of trust.



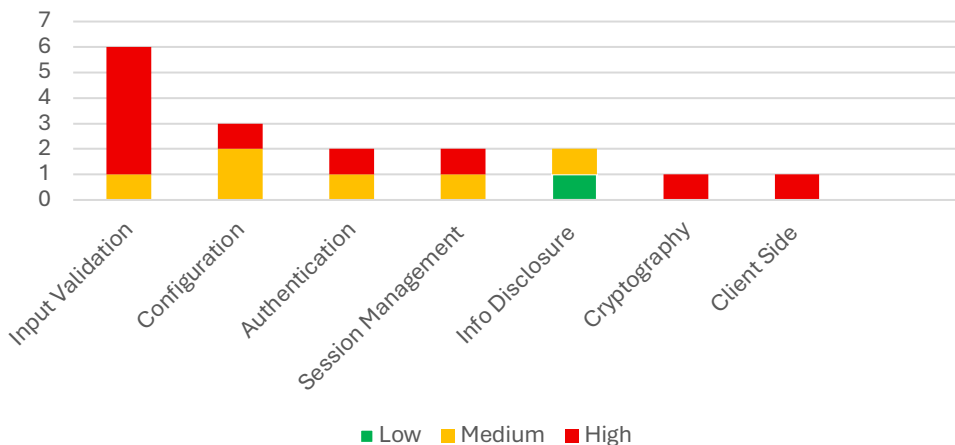
1.4 OVERALL RISK LEVEL

After analysing my findings in great detail I deem the web application currently as a Medium to high risk this is due to the presence of multiple vulnerabilities that can easily be exploited as well as the amount of information that is publicly accessible such as robots.txt and due to the insufficient security controls on the application.

ZAP Spider Attack Results



All Vulnerabilities Per Category and Risk Level



1.5 RECOMMENDATIONS

To reduce the risk and improve security it is highly recommended that BadStore:

- Implements string input validation and output sanitisation
- Improves authentication and session management mechanisms (2FA and session timeout)
- Apply security updates to outdated OS
- Introduce additional security controls to protect sensitive data.

DO NOT COPY

Technical Summary

2.1 SCOPE AND METHODOLOGY

I conducted my penetration test for BadStore against the web application within the defined scope of ports 80 and 443. The test followed the OWASP Web Security Testing Guide (WSTG), using both manual and automatic techniques.

A combination of tools was used(see Appendix 1.1) to perform enumeration, vulnerability scanning and exploitation including

- Nmap
- Nikto
- OWASP ZAP
- BurpSuite



2.2 VULNERABILITY OVERVIEW AND RECOMMENDATIONS

DO NOT COPY

ID	Vulnerability	Category	Risk Level	Likelihood	Impact	Recommendations
1	CVE-2001-1556 Log Injection	Input Validation	High	High	Manipulation of server logs.	- Implement strict input validation on all HTTP headers - Sanitise control characters before processing - Use secure logging frameworks that prevent log injection
2	CVE-2005-3352 Referer Header XSS	Input Validation	High	High	Session Hijacking, credential theft	- Validate and sanitise all HTTP header inputs - Apply output encoding before reflecting user input
3	CVE-2006-3918 Expect Header XSS	Input Validation	Medium	High	Potential script injection via HTTP headers	- Reject or sanitise non-standard HTTP Headers - Implement server-side validation of all incoming requests - Disable unnecessary header processing where possible
4	CVE-2006-5752 mod_status Exposure	Configuration	Medium	Medium	Information disclosure of server status	- Add Validation on apply - all URL parameters and input fields

DO NOT COPY

						- Encode user input before rendering HTML - Disable unused Apache Modules such as mod_imap
5	CVE-2007-5000 mod_imap XSS	Input Validation	High	Low	Limited due to lack of execution	- Implement strict server-side input validation - Use output encoding to prevent script execution
6	CVE-2007-6388 Input Validation XSS	Input Validation	High	High	JavaScript Execution, data theft	- Enforce validation on both client-side and server-side - Apply input validation on input fields, for example email addresses must contain a @ symbol - Use secure frameworks to handle user input safely.
7	Weak Password Policy	Authentication	Medium	High	Increased risk of accounts being compromised	- Enforce validation on both client-side and server-side - Apply length restrictions and format

DO NOT COPY

						validation for example email addresses must contain a @ symbol - Use secure frameworks to handle user input safely ‘
8	No account Lockout featured (after too many failed password attempts)	Authentication	High	High	Enables brute force attacks	- Implement account lockout after multiple failed login attempts) - Introduce CAPTCHA human verification to prevent brute force attacks
9	NO Session Timeout	Session Management	Medium	High	Session hijacking risk	- Implement automatic session expiration after inactivity - Require user to log back in after session has expired
10	Insecure cookies (HTTPOnly/SECURE is disabled)	Session Management	High	High	Cookie theft via XSS	- Enable HTTPOnly flag to prevent access via JavaScript - Enable Secure flag to ensure cookies are

DO NOT COPY

						only sent over HTTPS
12	Information Disclosure (email addresses on “sign out guestbook” page)	Information Disclosure	Medium	High	Enabled targeted phishing attacks	- Limited publicly accessible data
13	Robots.txt exposure	Information Disclosure	Low	Medium	Reveals usernames and application structure	- Remove sensitive data or restrict access
14	Missing Security Headers	Configuration	Medium	Medium	Increased attacks surface (XXS)	- Configure and enforce appropriate HTTP security headers
15	Outdated Apache server	Configuration	High	High	Vulnerable to known exploits (CVEs)	- Upgrade to supported version and check for updates regularly
16	Weak Cryptography (HTTP allowed)	Cryptography	High	High	Higher risk of man-in-the-middle attacks	- Enforce HTTPS - Redirect HTTP traffic
17	Client-side Validation bypass	Client-Side	High	High	Allows invalid or malicious input submission	- Implement server-side validation
18	Lack of input validation	Input Validation	High	High	Various injection-based attack opportunities	- Apply strict validation and input filtering

2.3 RISK ANALYSIS

My Penetration test of the BadStore web application identified several high-risk vulnerabilities primarily related to improper input validation and outdated software

High Risk

Input validation weaknesses and header injection vulnerabilities pose a significant risk due to their likelihood of exploitation and potentially to compromise user sessions and sensitive data

Medium Risk

DO NOT COPY

Issues such as information disclosure and weak configuration increase the attack surface and could support further server attacks

I have evaluated the overall risk based of the combinations of multiple exploitations and weaknesses across the application

4 Scope

The scope of engagement is limited to a certain 2 ports which are 80 and 443

Only the following vulnerabilities can be exploited:

- CVE-2001-1556
- CVE-2005-3352
- CVE-2006-3918
- CVE-2006-5752
- CVE-2007-5000
- CVE-2007-6388



Therefore, exploiting any other vulnerability is out of scope

- The use of social engineering Toolkit (SET) is out of scope, and interacting with the GRUB loader is also out of scop
- Interaction with the target should always occur trough Kali Linux

5. Rules of Engagement

3.Assessment Summary

6. OWASP METHODOLOGY

This penetration test was carried out using a clear structured methodology using the 12 step OWASP methodology. By using this approach there is focus on identifying, analysing and validating any security vulnerabilities in web applications allowing Bad Store to be clearly informed of any vulnerabilities from this test report, and enabling them to take relevant action were necessary.

6.1 INFORMATION GATHERING (WSTG- INFO)

Before conducting my penetration test, I must carry out an information gathering phase which aims to develop a deeper understanding of the target application, including its structure, technologies and potential attack surface. This allows the OWASP guidelines to ensure there is a comprehensive and logical approach before active testing begins.

NetDiscover



DO NOT COPY

```
kali@kali: ~  
Session Actions Edit View Help  
Currently scanning: 172.16.0.0/16 | Screen View: Unique Hosts  
6 Captured ARP Req/Rep packets, from 3 hosts. | Total size: 360  
-----  
IP      Inet6 Ref At MAC Address  Count  Len  MAC Vendor / Hostname  
-----  
192.168.10.1  00:50:56:c0:00:01  4      240  VMware, Inc.  
192.168.10.254 00:50:56:ec:ac:df  1       60  VMware, Inc.  
192.168.109.145 00:0c:29:09:de:27  1       60  VMware, Inc.  
-----  
TX errors 0 dropped 0 rx overruns 0 carrier 0 collisions 0
```

Figure 1

I have conducted a net discover command to identify the IP address of the target (see Figure 1). From this I can identify that the IP address is 192.168.109.145 this will allow me to progress with my penetration test.

WhatWeb-Passive

```
(kali@kali)~  
$ whatweb -v 192.168.211.134  
WhatWeb report for http://192.168.211.134  
Status : 200 OK  
Title : Welcome to BadStore.net v1.2.3s  
IP : 192.168.211.134  
Country : RESERVED, ZZ  
  
Summary : Apache[1.3.28][mod_ssl/2.8.15], HTTPServer[  
Unix][Apache/1.3.28 (Unix) mod_ssl/2.8.15 OpenSSL/0.9.7  
c], OpenSSL[0.9.7c]  
  
Detected Plugins:  
[ Apache ]  
The Apache HTTP Server Project is an effort to  
develop and  
maintain an open-source HTTP server for modern  
operating  
systems including UNIX and Windows NT. The goal  
of this  
project is to provide a secure, efficient and e  
xtensible  
server that provides HTTP services in sync with  
the current  
HTTP standards.  
  
Version : 1.3.28 (from HTTP Server Header)  
Module : mod_ssl/2.8.15  
Google Dorks: (3)  
Website : http://httpd.apache.org/  
  
[ HTTPServer ]  
HTTP server header string. This plugin also att  
empts to  
identify the operating system from the server h  
eader.  
  
OS : Unix  
String : Apache/1.3.28 (Unix) mod_ssl/2.8  
.15 OpenSSL/0.9.7c (from server string)
```

Figure 2

```
[ OpenSSL ]  
The OpenSSL Project is a collaborative effort t  
o develop a  
robust, commercial-grade, full-featured, and Op  
en Source  
toolkit implementing the Secure Sockets Layer (S  
SSL v2/v3)  
and Transport Layer Security (TLS v1) protocols  
as well as  
a full-strength general purpose cryptography li  
brary.  
  
Version : 0.9.7c  
Website : http://www.openssl.org/  
  
HTTP Headers:  
HTTP/1.1 200 OK  
Date: Fri, 20 Mar 2026 12:39:53 GMT  
Server: Apache/1.3.28 (Unix) mod_ssl/2.8.15 Ope  
nSSL/0.9.7c  
Last-Modified: Sun, 14 May 2006 21:16:23 GMT  
ETag: "14b-dff-44679e27"  
Accept-Ranges: bytes  
Content-Length: 3583  
Connection: close  
Content-Type: text/html  
  
WhatWeb report for https://192.168.211.134  
Status : 200 OK  
Title : Welcome to BadStore.net v1.2.3s  
IP : 192.168.211.134  
Country : RESERVED, ZZ  
  
Summary : Apache[1.3.28][mod_ssl/2.8.15], HTTPServer[  
Unix][Apache/1.3.28 (Unix) mod_ssl/2.8.15 OpenSSL/0.9.7  
c], OpenSSL[0.9.7c]  
  
Detected Plugins:  
[ Apache ]  
The Apache HTTP Server Project is an effort to  
develop and  
maintain an open-source HTTP server for modern
```

Figure 3

DO NOT COPY

```
maintain an open-source HTTP server for modern
operating
systems including UNIX and Windows NT. The goal
of this
project is to provide a secure, efficient and e
xtensible
server that provides HTTP services in sync with
the current
HTTP standards.

Version      : 1.3.28 (from HTTP Server Header)
Module       : mod_ssl/2.8.15
Google Dorks: (3)
Website      : http://httpd.apache.org/

[ HTTPServer ]
  HTTP server header string. This plugin also att
empts to
  identify the operating system from the server h
eader.

OS           : Unix
String       : Apache/1.3.28 (Unix) mod_ssl/2.8
.15 OpenSSL/0.9.7c (from server string)

[ OpenSSL ]
  The OpenSSL Project is a collaborative effort t
o develop a
  robust, commercial-grade, full-featured, and Op
en Source
  toolkit implementing the Secure Sockets Layer (
SSL v2/v3)
  and Transport Layer Security (TLS v1) protocols
  as well as
  a full-strength general purpose cryptography li
brary.

Version      : 0.9.7c
Website      : http://www.openssl.org/

HTTP Headers:
HTTP/1.1 200 OK
Date: Fri, 20 Mar 2026 12:39:53 GMT
```

Figure 4

As seen in figure 2,3 and 4 I used fingerprinting performed through what web as part of a passive reconnaissance to fingerprint the web application and identify underlying technologies this revealed details such as the web server, frameworks and scripting languages in use.

NMAP Vulners scan

Following a system wide nmap vulners scan I was able to identify numerous CVEs (full Nmap vulners see appendix 1.2)

```
| CVE-2004-0492 10.0 https://vulners.com/cve
/CVE-2004-0492
| 3E6BA608-776F-5B1F-9BA5-589CD2A5A351 10.0 h
tps://vulners.com/gitee/3E6BA608-776F-5B1F-9BA5-589CD2
A5A351 *EXPLOIT*
| HTTPD:B060BFAA862DD69F70DB2412EAE10DE9 7.8 h
tps://vulners.com/httpd/HTTPD:B060BFAA862DD69F70DB2412
EAE10DE9
| CVE-2004-0940 7.8 https://vulners.com/cve
/CVE-2004-0940
| SSV:6610 7.6 https://vulners.com/see
bug/SSV:6610 *EXPLOIT*
| SSV:63874 7.6 https://vulners.com/see
bug/SSV:63874 *EXPLOIT*
| SSV:429 7.6 https://vulners.com/seebug/SSV:
429 *EXPLOIT*
| SSV:16391 7.6 https://vulners.com/see
bug/SSV:16391 *EXPLOIT*
| SAINT:B572402CE6E5C851D7572BF044507A14 7.6 h
tps://vulners.com/saint/SAINT:B572402CE6E5C851D7572BF0
```

DO NOT COPY

```
| CVE-2006-3747 7.6 https://vulners.com/cve  
/CVE-2006-3747  
| HTTPD:EA65344DAE2D5CDBD3227D99A03949E9 7.5 h  
https://vulners.com/httpd/HTTPD:EA65344DAE2D5CDBD3227D99  
A03949E9  
| HTTPD:67FAF457E140172987C21E55FCF24788 7.5 h  
https://vulners.com/httpd/HTTPD:67FAF457E140172987C21E55  
FCF24788  
| HTTPD:0576286DB2485FBB76346020044ABE4A 7.5 h  
https://vulners.com/httpd/HTTPD:0576286DB2485FBB76346020  
044ABE4A  
| CVE-2004-1082 7.5 https://vulners.com/cve  
/CVE-2004-1082  
| CVE-2003-0993 7.5 https://vulners.com/cve  
/CVE-2003-0993  
| CVE-2003-0987 7.5 https://vulners.com/cve  
/CVE-2003-0987  
| HTTPD:18EAF7F92541BF62857123A840724D27 7.2 h  
https://vulners.com/httpd/HTTPD:18EAF7F92541BF62857123A8  
40724D27  
| CVE-2003-0542 7.2 https://vulners.com/cve  
/CVE-2003-0542  
| SSV:19019 6.8 https://vulners.com/see  
bug/SSV:19019 *EXPLOIT*  
| HTTPD:C7445200CAFE5527BA15F7BB8AF90D9F 6.8 h  
https://vulners.com/httpd/HTTPD:C7445200CAFE5527BA15F7BB  
8AF90D9F  
| CVE-2010-0010 6.8 https://vulners.com/cve  
/CVE-2010-0010  
| SSV:66957 5.0 https://vulners.com/see  
bug/SSV:66957 *EXPLOIT*
```

```
/CVE-2011-3368  
| CVE-2007-6750 5.0 https://vulners.com/cve  
/CVE-2007-6750  
| CVE-2004-0263 5.0 https://vulners.com/cve  
/CVE-2004-0263  
| CVE-2003-0020 5.0 https://vulners.com/cve  
/CVE-2003-0020  
| CVE-2001-1556 5.0 https://vulners.com/cve  
/CVE-2001-1556  
| SSV:2174 4.7 https://vulners.com/see  
bug/SSV:2174 *EXPLOIT*  
| HTTPD:B63CF0157386C00B8FF9E943DA8F9A2F 4.7 h  
https://vulners.com/httpd/HTTPD:B63CF0157386C00B8FF9E943  
DA8F9A2F  
| CVE-2007-3304 4.7 https://vulners.com/cve  
/CVE-2007-3304  
| SSV:71772 4.3 https://vulners.com/see  
bug/SSV:71772 *EXPLOIT*  
| SSV:2818 4.3 https://vulners.com/see  
bug/SSV:2818 *EXPLOIT*  
| SSV:2801 4.3 https://vulners.com/see  
bug/SSV:2801 *EXPLOIT*  
| SSV:24250 4.3 https://vulners.com/see  
bug/SSV:24250 *EXPLOIT*  
| PACKETSTORM:61420 4.3 https://vulners  
.com/packetstorm/PACKETSTORM:61420 *EXPLOIT*
```

```
| CVE-2011-4317 4.3 https://vulners.com/cve  
/CVE-2011-4317  
| CVE-2007-6388 4.3 https://vulners.com/cve  
/CVE-2007-6388  
| CVE-2007-5000 4.3 https://vulners.com/cve  
/CVE-2007-5000  
| CVE-2006-5752 4.3 https://vulners.com/cve  
/CVE-2006-5752  
| CVE-2006-3918 4.3 https://vulners.com/cve  
/CVE-2006-3918  
| CVE-2005-3352 4.3 https://vulners.com/cve  
/CVE-2005-3352  
| 1337DAY-ID-9952 0.0 https://vulners.com/zdt  
/1337DAY-ID-9952 *EXPLOIT*  
| 1337DAY-ID-6193 0.0 https://vulners.com/zdt  
/1337DAY-ID-6193 *EXPLOIT*  
| 1337DAY-ID-16843 0.0 https://vulners  
.com/zdt/1337DAY-ID-16843 *EXPLOIT*  
| 1337DAY-ID-16323 0.0 https://vulners  
.com/zdt/1337DAY-ID-16323 *EXPLOIT*  
443/tcp open ssl/http Apache httpd 1.3.28 ((Unix) mod  
_ssl/2.8.15 OpenSSL/0.9.7c)  
|_http-server-header: Apache/1.3.28 (Unix) mod_ssl/2.8.  
15 OpenSSL/0.9.7c  
| vulners:  
| cpe:/a:apache:http_server:1.3.28:  
| HTTPD:186F8E9AD2C9495C370F3BFADE6F3CC4 10.0 h  
https://vulners.com/httpd/HTTPD:186F8E9AD2C9495C370F3BFA
```



DO NOT COPY

```
/CVE-2004-0492
3E6BA608-776F-5B1F-9BA5-589CD2A5A351 10.0 h
https://vulners.com/gitee/3E6BA608-776F-5B1F-9BA5-589CD2
A5A351 *EXPLOIT*
HTTPD:B060BFAA862DD69F70DB2412EAE10DE9 7.8 h
https://vulners.com/httpd/HTTPD:B060BFAA862DD69F70DB2412
EAE10DE9
CVE-2004-0940 7.8 https://vulners.com/cve
/CVE-2004-0940
SSV:6610 7.6 https://vulners.com/see
bug/SSV:6610 *EXPLOIT*
SSV:63874 7.6 https://vulners.com/see
bug/SSV:63874 *EXPLOIT*
SSV:429 7.6 https://vulners.com/seebug/SSV:
429 *EXPLOIT*
SSV:16391 7.6 https://vulners.com/see
bug/SSV:16391 *EXPLOIT*
SAINT:B572402CE6E5C851D7572BF044507A14 7.6 h
https://vulners.com/saint/SAINT:B572402CE6E5C851D7572BF0
44507A14 *EXPLOIT*
```

```
| CVE-2004-1082 7.5 https://vulners.com/cve
/CVE-2004-1082
| CVE-2003-0993 7.5 https://vulners.com/cve
/CVE-2003-0993
| CVE-2003-0987 7.5 https://vulners.com/cve
/CVE-2003-0987
| HTTPD:18EAF7F92541BF62857123A840724D27 7.2 h
https://vulners.com/httpd/HTTPD:18EAF7F92541BF62857123A8
40724D27
| CVE-2003-0542 7.2 https://vulners.com/cve
/CVE-2003-0542
| SSV:19019 6.8 https://vulners.com/see
bug/SSV:19019 *EXPLOIT*
| HTTPD:C7445200CAFE5527BA15F7BB8AF90D9F 6.8 h
https://vulners.com/httpd/HTTPD:C7445200CAFE5527BA15F7BB
8AF90D9F
| CVE-2010-0010 6.8 https://vulners.com/cve
/CVE-2010-0010
| SSV:66957 5.0 https://vulners.com/see
```

```
| CVE-2011-3368 5.0 https://vulners.com/cve
/CVE-2011-3368
| CVE-2007-6750 5.0 https://vulners.com/cve
/CVE-2007-6750
| CVE-2004-0263 5.0 https://vulners.com/cve
/CVE-2004-0263
| CVE-2003-0020 5.0 https://vulners.com/cve
/CVE-2003-0020
| CVE-2001-1556 5.0 https://vulners.com/cve
/CVE-2001-1556
| SSV:2174 4.7 https://vulners.com/see
bug/SSV:2174 *EXPLOIT*
| HTTPD:B63CF0157386C00B8FF9E943DA8F9A2F 4.7 h
https://vulners.com/httpd/HTTPD:B63CF0157386C00B8FF9E943
DA8F9A2F
| CVE-2007-3304 4.7 https://vulners.com/cve
/CVE-2007-3304
| SSV:71772 4.3 https://vulners.com/see
bug/SSV:71772 *EXPLOIT*
| SSV:2818 4.3 https://vulners.com/see
bug/SSV:2818 *EXPLOIT*
| SSV:2801 4.3 https://vulners.com/see
```



NMAPs-Active

```
(kali@kali)-[~]
$ nmap -sn 192.168.18.133
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-26 07:16 -0400
Nmap scan report for 192.168.18.133
Host is up (0.00062s latency).
MAC Address: 00:0C:29:D5:B1:AD (VMware)
Nmap done: 1 IP address (1 host up) scanned in 4.66 seconds
```

Figure 5

DO NOT COPY

As seen above in figure 5 I conducted an Nmap scan to complete host discovery as a form of active reconnaissance this is essential to see any live hosts on the target

```
(kali@kali)-[~]
$ nmap -sS 192.168.18.133
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-26 07:20 -0400
Nmap scan report for 192.168.18.133
Host is up (0.0021s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
80/tcp    open  http
443/tcp   open  https
3306/tcp   open  mysql
MAC Address: 00:0C:29:D5:B1:AD (VMware)
Nmap done: 1 IP address (1 host up) scanned in 4.86 seconds
```

Figure 6

The nmap scan in figure 6 is crucial so I can see any open ports on the target system as seen in figure 6 there are 997 closed ports and 3 open ports

```
(kali@kali)-[~]
$ nmap -sV 192.168.18.133
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-26 07:22 -0400
Nmap scan report for 192.168.18.133
Host is up (0.00088s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
80/tcp    open  http         Apache httpd 1.3.28 ((Unix) mod_ssl/2.8.15 OpenSSL/0.9.7c)
443/tcp   open  ssl/http     Apache httpd 1.3.28 ((Unix) mod_ssl/2.8.15 OpenSSL/0.9.7c)
3306/tcp   open  mysql        MySQL 4.1.7-standard
MAC Address: 00:0C:29:D5:B1:AD (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 17.50 seconds
```

Figure 7 Identifies running services and versions XX

In figure 7 I have carried out an nmap scan to see Services and Versions on the target system as visual in figure 7 the active services are HTTP, SSL/HTTP and MySQL.

```
(kali@kali)-[~]
$ nmap -A -T4 192.168.18.133
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-26 07:27 -0400
Nmap scan report for 192.168.18.133
Host is up (0.00093s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
80/tcp    open  http         Apache/1.3.28 ((Unix) mod_ssl/2.8.15 OpenSSL/0.9.7c)
|_ http-server-header: Apache/1.3.28 ((Unix) mod_ssl/2.8.15 OpenSSL/0.9.7c)
|_ http-robots.txt: 5 disallowed entries
|_ /cgi-bin /scanbot /backup /supplier /upload
|_ http-title: Welcome to BadStore.net v1.2.3s
|_ http-methods:
|_ Potentially risky methods: TRACE
|_ http-server-header: Apache/1.3.28 ((Unix) mod_ssl/2.8.15 OpenSSL/0.9.7c)
443/tcp   open  ssl/http     Apache httpd 1.3.28 ((Unix) mod_ssl/2.8.15 OpenSSL/0.9.7c)
|_ ssl-date: 2026-03-26T11:28:19+00:00; -2s from scanner time.
|_ http-title: Welcome to BadStore.net v1.2.3s
|_ http-methods:
|_ Potentially risky methods: TRACE
|_ http-robots.txt: 5 disallowed entries
|_ /cgi-bin /scanbot /backup /supplier /upload
|_ ssl-certs: Subject: commonName=www.badstore.net/organizationName=BadStore.net/stateOrProvinceName=Illinois/countryName=US
|_ Subject Alternative Name: email=root@badstore.net
|_ Not valid before: 2006-05-10T12:52:53
|_ Not valid after: 2009-02-02T12:52:53
|_ sslv2:
|_ SSLv2 supported
|_ ciphers:
|_ SSL2_RC4_128_EXPORT40_WITH_MD5
|_ SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_ SSL2_RC4_128_WITH_MD5
|_ SSL2_IDEA_128_CBC_WITH_MD5
|_ SSL2_RC2_128_CBC_WITH_MD5
|_ SSL2_DES_192_EDE3_CBC_WITH_MD5
|_ SSL2_RC4_64_WITH_MD5
|_ SSL2_DES_64_CBC_WITH_MD5
|_ http-server-header: Apache/1.3.28 ((Unix) mod_ssl/2.8.15 OpenSSL/0.9.7c)
3306/tcp   open  mysql        MySQL 4.1.7-standard
|_ mysql-info:
|_ Protocol: 10
|_ Version: 4.1.7-standard
|_ Thread ID: 7
|_ Capabilities flags: 33324
|_ Some Capabilities: SupportsCompression, Support41Auth, LongColumnFlag, ConnectWithDatabase, Speaks41ProtocolNew
|_ Status: Autocommit
|_ Salt: r'i]tS'L:))p7'_'=Q'fc
MAC Address: 00:0C:29:D5:B1:AD (VMware)
```

Figure 8

DO NOT COPY

```
Device type: general purpose
Running: Linux 2.4.X
OS CPE: cpe:/o:linux:linux_kernel:2.4
OS details: Linux 2.4.18 - 2.4.35 (likely embedded)
Network Distance: 1 hop

Host script results:
|_clock-skew: -2s

TRACEROUTE
HOP RTT ADDRESS
1 0.93 ms 192.168.18.133

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 60.12 seconds
```

Figure 9

Figures 8 and 9 above show an Nmap scan to complete a full enumeration of the target this allows me to carry out reconnaissance and discover Operating Systems, Services and scripts.

```
(kali@kali)~$ nmap --script http-enum,http-methods -p 80,443 192.168.18.133
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-26 07:34 -0400
Nmap scan report for 192.168.18.133
Host is up (0.00096s latency).

PORT      STATE SERVICE
80/tcp    open  http
|_ http-methods:
|_ Supported Methods: GET HEAD OPTIONS TRACE
|_ Potentially risky methods: TRACE
|_ http-headers:
|_ Date: Thu, 26 Mar 2026 11:34:54 GMT
|_ Server: Apache/1.3.28 (Unix) mod_ssl/2.8.15 OpenSSL/0.9.7c
|_ Last-Modified: Sun, 14 May 2006 21:16:23 GMT
|_ ETag: "14b-dff-44679e27"
|_ Accept-Ranges: bytes
|_ Content-Length: 3583
|_ Connection: close
|_ Content-Type: text/html
|_ (Request type: HEAD)
|_ http-enum:
|_ /backup/: Backup folder w/ directory listing
|_ /robots.txt: Robots file
|_ /icons/: Potentially interesting directory w/ listing on 'apache/1.3.28'
|_ /images/: Potentially interesting directory w/ listing on 'apache/1.3.28'
|_ /supplier/: Potentially interesting directory w/ listing on 'apache/1.3.28'
443/tcp    open  https
|_ http-methods:
|_ Supported Methods: GET HEAD OPTIONS TRACE
|_ Potentially risky methods: TRACE
|_ http-enum:
|_ /backup/: Backup folder w/ directory listing
|_ /robots.txt: Robots file
|_ /icons/: Potentially interesting directory w/ listing on 'apache/1.3.28'
|_ /images/: Potentially interesting directory w/ listing on 'apache/1.3.28'
|_ /supplier/: Potentially interesting directory w/ listing on 'apache/1.3.28'
|_ http-headers:
|_ Date: Thu, 26 Mar 2026 11:34:54 GMT
|_ Server: Apache/1.3.28 (Unix) mod_ssl/2.8.15 OpenSSL/0.9.7c
|_ Last-Modified: Sun, 14 May 2006 21:16:23 GMT
|_ ETag: "14b-dff-44679e27"
|_ Accept-Ranges: bytes
|_ Content-Length: 3583
|_ Connection: close
|_ Content-Type: text/html
|_ (Request type: HEAD)
MAC Address: 00:0C:29:D5:B1:AD (VMware)

Nmap done: 1 IP address (1 host up) scanned in 6.81 seconds
```

DO NOT COPY

Figure 10

Figure 10 shows I have conducted a web enumeration nmap scan using NSE scripts including http-Enum, http-headers and http-methods to identify accessible endpoints and gather additional information about the web server configuration

Gobuster- Active

```
(kali@kali)~$ gobuster dir -u 192.168.211.134 -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[*] Url: http://192.168.211.134
[*] Method: GET
[*] Threads: 10
[*] Wordlist: /usr/share/wordlists/dirb/common.txt
[*] Negative Status codes: 404
[*] User Agent: gobuster/3.8.2
[*] Timeout: 10s

Starting gobuster in directory enumeration mode

.htaccess (Status: 403) [Size: 279]
.htpasswd (Status: 403) [Size: 279]
backup (Status: 301) [Size: 306] [→ http://192.168.211.134/backup/]
.nfta (Status: 403) [Size: 274]
cgi-bin/ (Status: 403) [Size: 278]
favicon.ico (Status: 200) [Size: 1334]
images (Status: 301) [Size: 306] [→ http://192.168.211.134/images/]
index (Status: 200) [Size: 3583]
index.html (Status: 200) [Size: 3583]
robots (Status: 200) [Size: 316]
robots.txt (Status: 200) [Size: 316]
supplier (Status: 301) [Size: 308] [→ http://192.168.211.134/supplier/]
Progress: 4613 / 4613 (100.00%)
Finished
```

Figure 11- Discovers hidden directories such as /admin and /login

As seen in figure 11 the use of gobuster meant I was able to scan for wordlists and discover of /admin, /login, and /backup endpoints allowed me to identify key application entry points, including authentication interfaces and potentially sensitive directories.

BurpSuite-Active

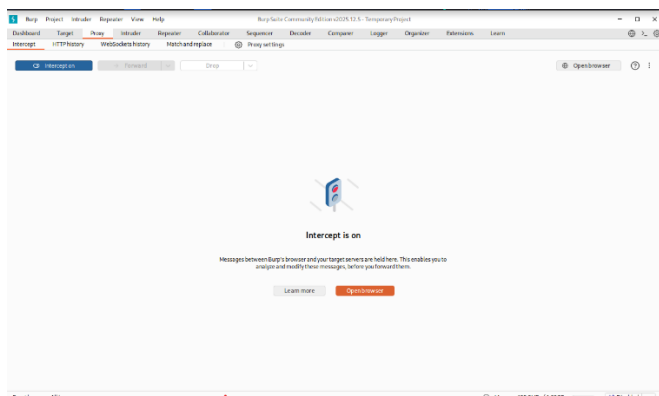


Figure 12

Figure 13 shows the use of burp suite which is being used to view packets that are being

DO NOT COPY

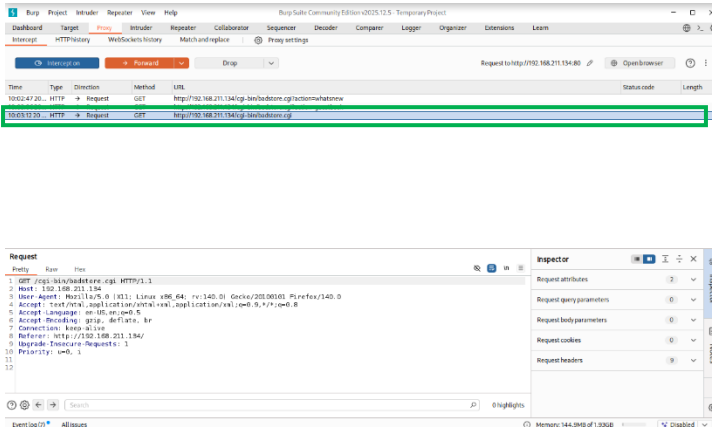


Figure 13

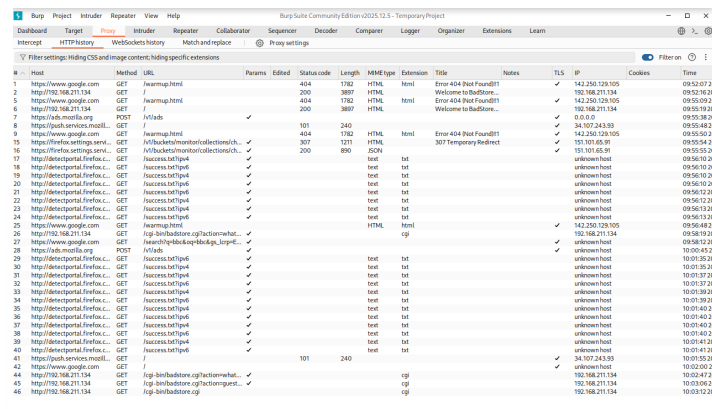


Figure 14

Figure 14 s a site map produced when using burp suite this is crucial within my gathering information stage of the OWASP methodology as it allows me to view the target system any endpoints it may have. It also allows me to see a hierarchical structure of the target by organising domains, subdomains and directories as well as content discovery, burp suit will list all pages, files and resources found on the target system

6.2 CONFIGURATION AND DEPLOYMENT MANAGEMENT TESTING (WSTG-CONF)

Configuration and development testing identified several misconfigurations and vulnerabilities within the application. Many of these issues suggest weaknesses in the server configuration that could be leveraged by an attacker attackers.

Nikto Scan- Port 80

DO NOT COPY

```
(kali@kali)~$ nikto -h 192.168.224.130 -p 80,443
- Nikto v2.5.0

+ Target IP: 192.168.224.130
+ Target Hostname: 192.168.224.130
+ Target Port: 80
+ Start Time: 2026-03-17 07:59:15 (GMT-4)

+ Server: Apache/1.3.28 (Unix) mod_ssl/2.8.15 OpenSSL/0.9.7c
+ /: Server may leak inodes via ETags, header found with file /, inode: 331, size: 3583, mtime: Sun May 14 17:16:23 2006. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ /supplier/: Directory indexing found.
+ /robots.txt: Entry '/supplier/' is returned a non-forbidden or redirect HTTP code (200). See: https://portswigger.net/kb/issues/006006000_robots-txt-file
+ /backup/: Directory indexing found.
+ /robots.txt: Entry '/backup/' is returned a non-forbidden or redirect HTTP code (200). See: https://portswigger.net/kb/issues/006006000_robots-txt-file
+ /robots.txt: contains 6 entries which should be manually viewed. See: https://developer.mozilla.org/en-US/docs/Glossary/Robots.txt
+ OpenSSL/0.9.7c appears to be outdated (current is at least 3.0.7). OpenSSL 1.1.1s is current for the 1.x branch and will be supported until Nov 11 2023.
+ Apache/1.3.28 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ mod_ssl/2.8.15 appears to be outdated (current is at least 2.9.6) (may depend on server version).
+ /: Apache is vulnerable to XSS via the Expect header. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2006-3918
+ /index: Uncommon header 'tcn' found, with contents: list.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.html. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ OPTIONS: Allowed HTTP Methods: GET, HEAD, OPTIONS, TRACE
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ Apache/1.3.28 - Apache 1.3 below 1.3.29 are vulnerable to overflows in mod_rewrite and mod_cgi.
+ /backup/: This might be interesting.
+ /cgi-bin/test.cgi: This might be interesting.
+ /icons/: Directory indexing found.
+ /images/: Directory indexing found.
+ /wp-config.php#: #wp-config.php# file found. This file contains the credentials.
+ 8915 requests: 0 error(s) and 22 item(s) reported on remote host
+ End Time: 2026-03-17 07:59:24 (GMT-4) (9 seconds)
```

Figure 15

From figure 3 I can see that the web application is running Apache 1.3.28 with OpenSSL which is very old and outdated. It is also missing certain security headers which can lead to sniffing attacks. Finally there is also a major risk due to credential exposure, mysql_config.php contains credentials which could lead to a full compromise

Port 443

```
+ Target IP: 192.168.224.130
+ Target Hostname: 192.168.224.130
+ Target Port: 443

+ SSL Info: Subject: /C=US/ST=Illinois/L=Grayslake/O=BadStore.net/OU=Crack Development Team/CN=www.badstore.net/emailAddress=root@badstore.net
+ Ciphers: DHE-RSA-AES256-SHA
+ Issuer: /C=XY/ST=Snake Desert/L=Snake Town/O=Snake Oil, Ltd/OU=Certificate Authority/CN=Snake Oil
+ Start Time: 2026-03-17 07:59:24 (GMT-4)

+ Server: Apache/1.3.28 (Unix) mod_ssl/2.8.15 OpenSSL/0.9.7c
+ /: Server may leak inodes via ETags, header found with file /, inode: 331, size: 3583, mtime: Sun May 14 17:16:23 2006. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The site uses TLS and the Strict-Transport-Security HTTP header is not defined. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ All CGI directories 'found', use '-C none' to test none
+ /robots.txt: Entry '/supplier/' is returned a non-forbidden or redirect HTTP code (200). See: https://portswigger.net/kb/issues/006006000_robots-txt-file
+ /robots.txt: Entry '/backup/' is returned a non-forbidden or redirect HTTP code (200). See: https://portswigger.net/kb/issues/006006000_robots-txt-file
+ /robots.txt: contains 6 entries which should be manually viewed. See: https://developer.mozilla.org/en-US/docs/Glossary/Robots.txt
+ Apache/1.3.28 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ OpenSSL/0.9.7c appears to be outdated (current is at least 3.0.7). OpenSSL 1.1.1s is current for the 1.x branch and will be supported until Nov 11 2023.
+ mod_ssl/2.8.15 appears to be outdated (current is at least 2.9.6) (may depend on server version).
+ /: Apache is vulnerable to XSS via the Expect header. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2006-3918
+ Hostname '192.168.224.130' does not match certificate's names: www.badstore.net. See: https://cve.mitre.org/data/definitions/297.html
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.html. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ OPTIONS: Allowed HTTP Methods: GET, HEAD, OPTIONS, TRACE
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ Apache/1.3.28 - Apache 1.3 below 1.3.29 are vulnerable to overflows in mod_rewrite and mod_cgi.
+ /backup/: This might be interesting.
+ /cgi-bin/test.cgi: This might be interesting.
+ /icons/: Directory indexing found. See: http://projects.webappsec.org/w/page/13246922/Directory%20Indexing
+ /images/: Directory indexing found. See: http://projects.webappsec.org/w/page/13246922/Directory%20Indexing
+ /wp-config.php#: #wp-config.php# file found. This file contains the credentials.
+ 17805 requests: 0 error(s) and 21 item(s) reported on remote host
+ End Time: 2026-03-17 08:01:09 (GMT-4) (105 seconds)

+ 2 host(s) tested
```

Figure 16

From the Figure above it is also running an outdated version of Apache version 1.3.28 running old versions like this poses a high risk to the system as there are no longer security updates from the developer this exposes the system to much greater risk and makes it much easier for a threat actor to compromise this system.

DO NOT COPY

Zap Spider attack

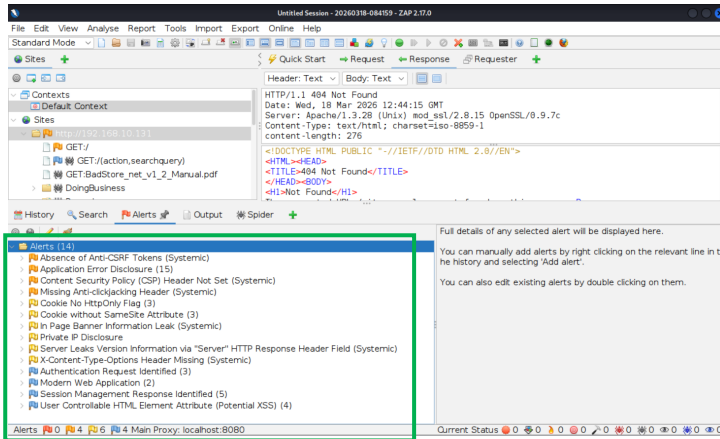


Figure 17

In figure 17 I have user zap spider this is used to crawl the web application and identify accessible URLs, directories and parameters. This allows me to reveal the structure of the application and potential entry points when it comes to further testing

Zap AJAX Spider

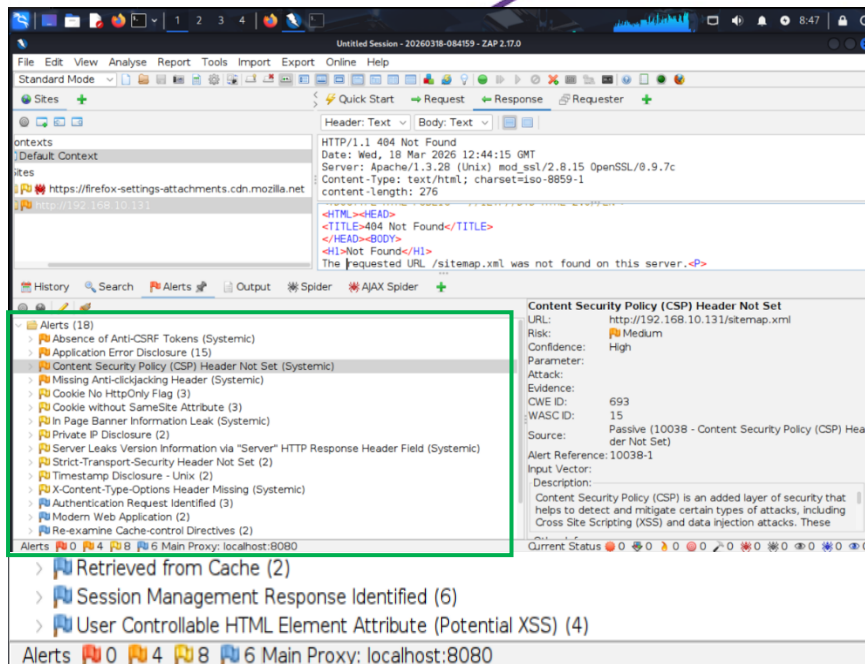


Figure 18

The use of AJAX spider in figure 18 allowed me to execute java script to discover hidden generated content that isn't visible through ordinary zap spidering this enhances step 2 of OWASP by uncovering additional attack surfaces.

6.3 IDENTITY MANAGEMENT TESTING (WSTG-ID)

The purpose of this step is to see how the BadStore web application identifies its users and to determine whether user accounts can be unmerated or exposed to an attacker.

1. Exposure of user email addresses

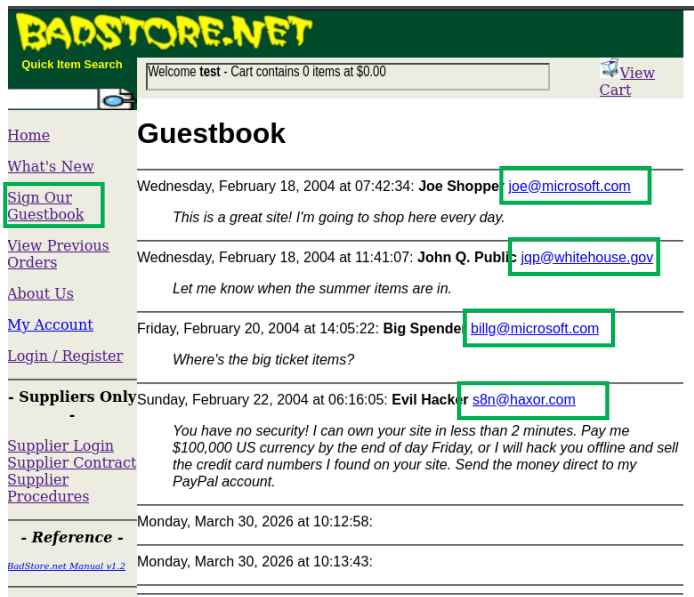


Figure 19

In figure 19 The web application displays email addresses publicly on the "sign our guestbook" page. This could allow an attacker to collect email addresses which can be used for targeted phishing attacks. This could be mitigated by limiting the amount of information publicly visible for example on the guest book include names but not email addresses.

2. Lack of Validation

DO NOT COPY

Quick Item Search

Welcome bob - Cart contains 0 items at \$0.00

[View Cart](#)

[Home](#)
[What's New](#)
[Login Our Guestbook](#)
[View Previous Orders](#)
[About Us](#)
[My Account](#)
[Login / Register](#)
[Suppliers Only](#)
[Supplier Login](#)
[Supplier Contract](#)
[Supplier Procedures](#)
[Reference](#)

Login to Your Account or Register for a New Account

Login to Your Account

Email Address:

Password:

Register for a New Account

Full Name:

Email Address:

Password:

Password Hint - What's Your Favorite Color?:

(The Password Hint is used as a security measure to help recover a forgotten password. You will need both your email address and this hint to access your account if you forget your current password.)

Figure 20

From figure 19 within the web application, it is possible to create an account using the same name and email address this displays insufficient validation when registering new accounts whilst this is a low/medium risk this weakness could allow attackers to create multiple accounts impersonating legitimate users or suppliers. This could be mitigated by adding constraints on username and email addresses at the application and database levels.

This email addresses found were tested with common passwords on the web applications login page however were all unsuccessful.

6.4 AUTHENTICATION TESTING (WSTG-ATHN) (WSTG-ATHZ)

The purpose of this stage is to assess the strength of the authentication implemented by the BadStore web application.

1. Weak password policy

The web application accepts weak passwords this is a medium risk as accounts can easily be compromised this can be mitigated by implementing password rule such as must be at least 8 characters long, include upper and lower case, numbers and at least 1 special character.

Register for a New Account

Full Name:

Email Address:

Password:

Password Hint - What's Your Favorite Color?:

(The Password Hint is used as a security measure to help recover a forgotten password. You will need both your email address and this hint to access your account if you forget your current password.)

BADSTORE.NET

Quick Item Search

Welcome test - Cart contains 0 items at \$0.00

[View Cart](#)

Figure 21

DO NOT COPY

As seen in figure 21, when attempting to create an account named test and using a basic password “1234” I am successfully able to create an account using these insecure credentials.

Default credential testing was conducted (such as username admin password admin) no valid credentials were identified.



2. No account lockout after multiple failure login attempts.

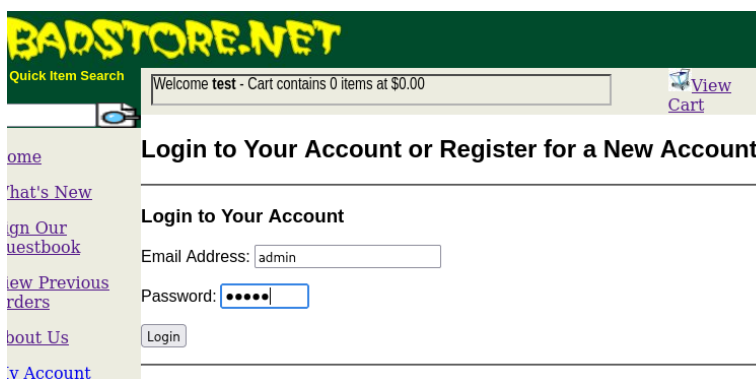
The screenshot shows the login page of BADSTORE.NET. At the top, there is a green header with 'BADSTORE.NET' in yellow. Below the header, there is a navigation menu on the left with links: 'Home', 'What's New', 'Sign Our Newsletter', 'View Previous Orders', 'About Us', and 'My Account'. The main content area has a welcome message: 'Welcome test - Cart contains 0 items at \$0.00' and a 'View Cart' link. Below this, there is a section titled 'Login to Your Account or Register for a New Account'. Underneath, there is a 'Login to Your Account' section with an 'Email Address' field containing 'admin' and a 'Password' field with five dots. A 'Login' button is located below the password field.

Figure 22

DO NOT COPY

As from figure 22 I attempted to fail to provide correct passwords to login to a user account and after more than 10 attempts there was no form of lock out for the account or even any warning that continued fail attempts will lead to the account being locked. This is high risk as it enables brute force attacks the main step to mitigating this risk would be to implement an account lockout system after a certain amount of failed login attempts.

6.5 AUTHENTICATION TESTING (WSTG-ATHN) (WSTG-ATHZ)

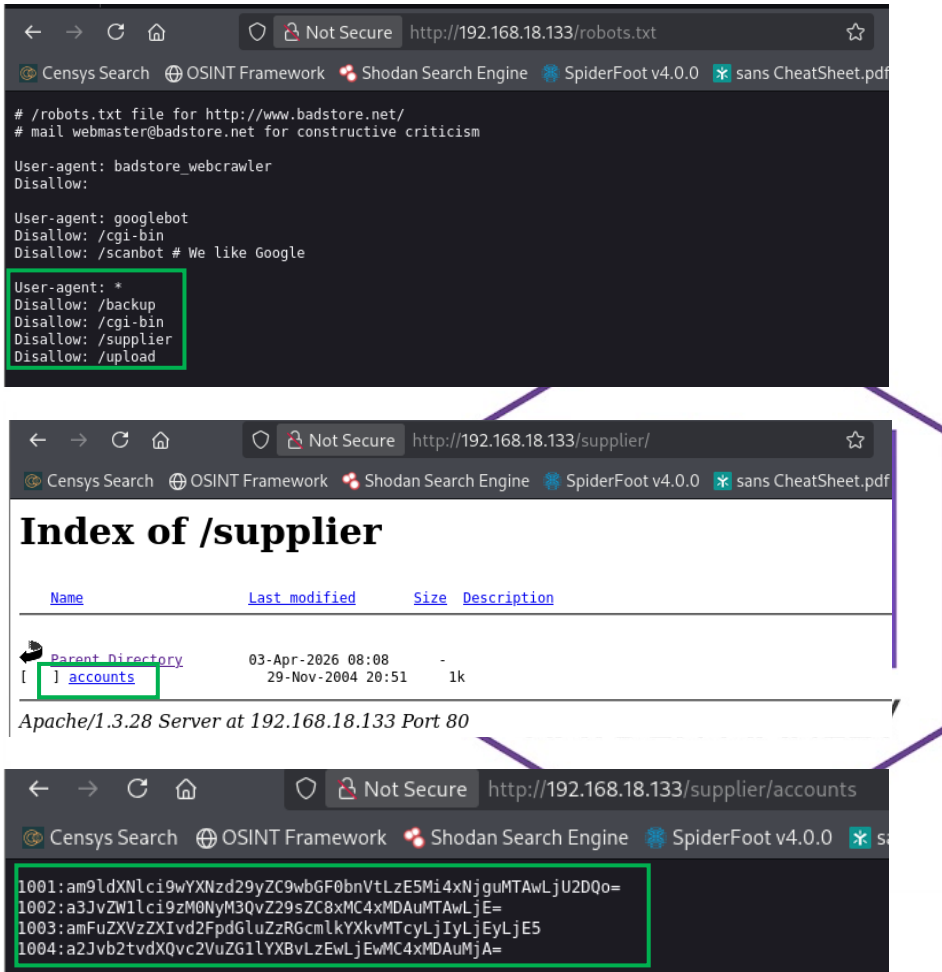


Figure 23

By changing the URL I can access the robots.txt allowing me to find supplier usernames registered on the web application this is publicly accessible.

6.6 SESSION MANAGEMENT TESTING (WSTG-SESS)

This step was to evaluate the security of session management including session identifies, cookie handing.

1. Session handling

DO NOT COPY

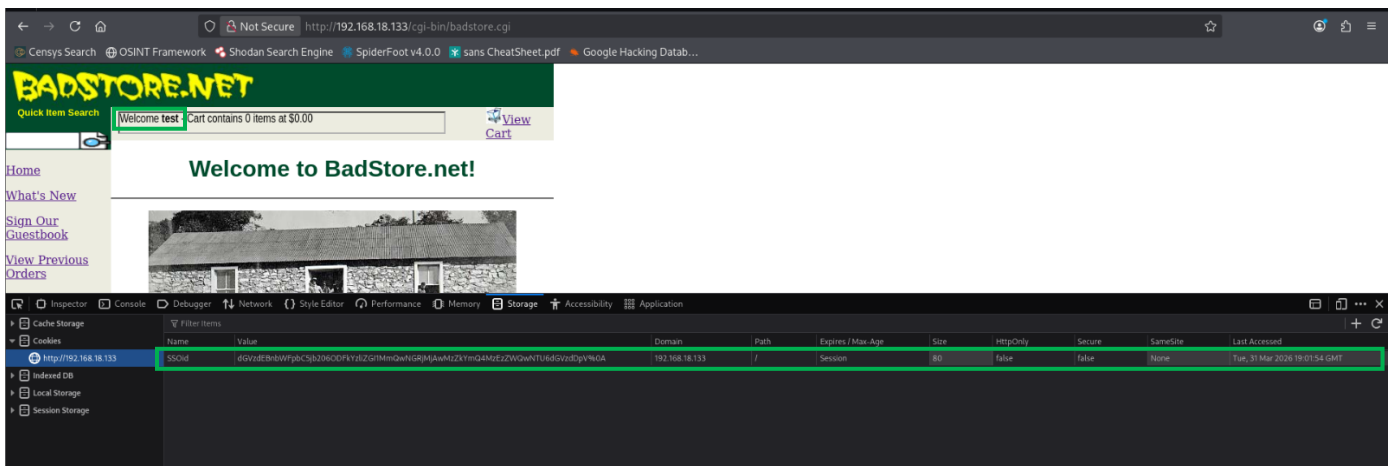
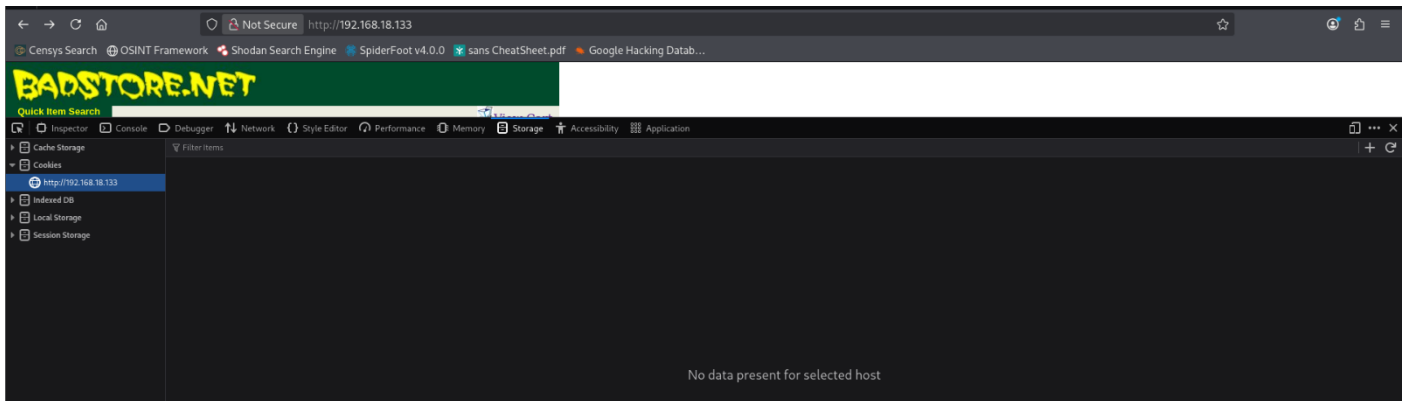


Figure 24

As per figure 25, by conducting the shown session management test I identified that no session cookie was issued prior to account authorisation, this generates appropriate session handling as session identifiers are not exposed to unauthorised users. Once a successful login occurs a cookie is generated this is secure and reduces the risk of session attacks.

2. Cookie Security

DO NOT COPY

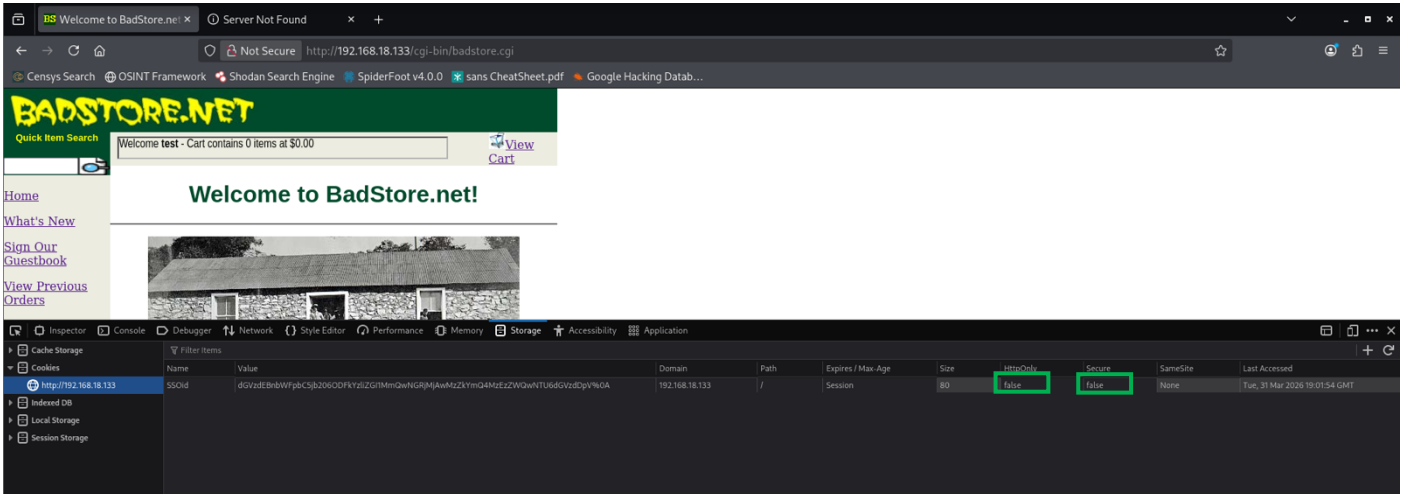
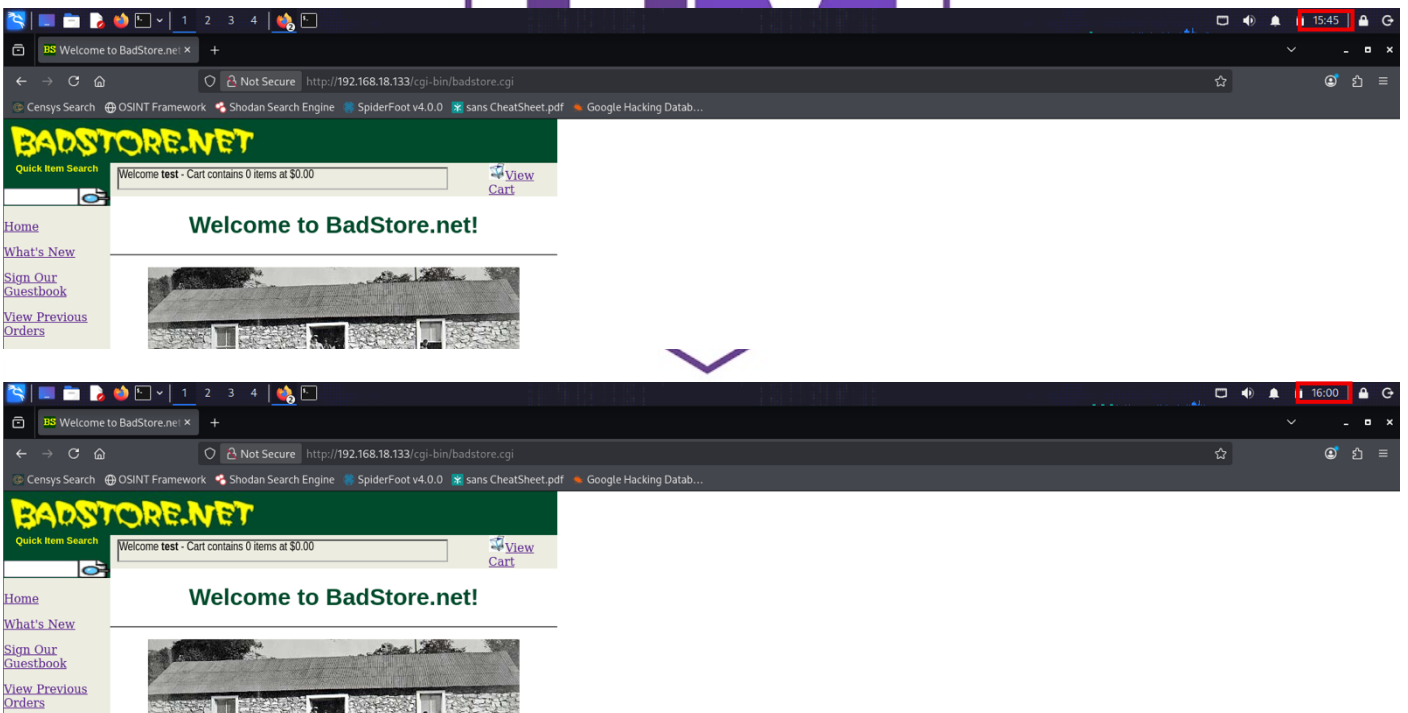


Figure 25

After looking into the site cookies as seen in figure 24 the HTTP only and secure fields show as false this can cause the cookies to be stolen via XSS(Cross site scripting) a key mitigation for this would be to enable HTTP only and secure flags.

3. Session Timeout

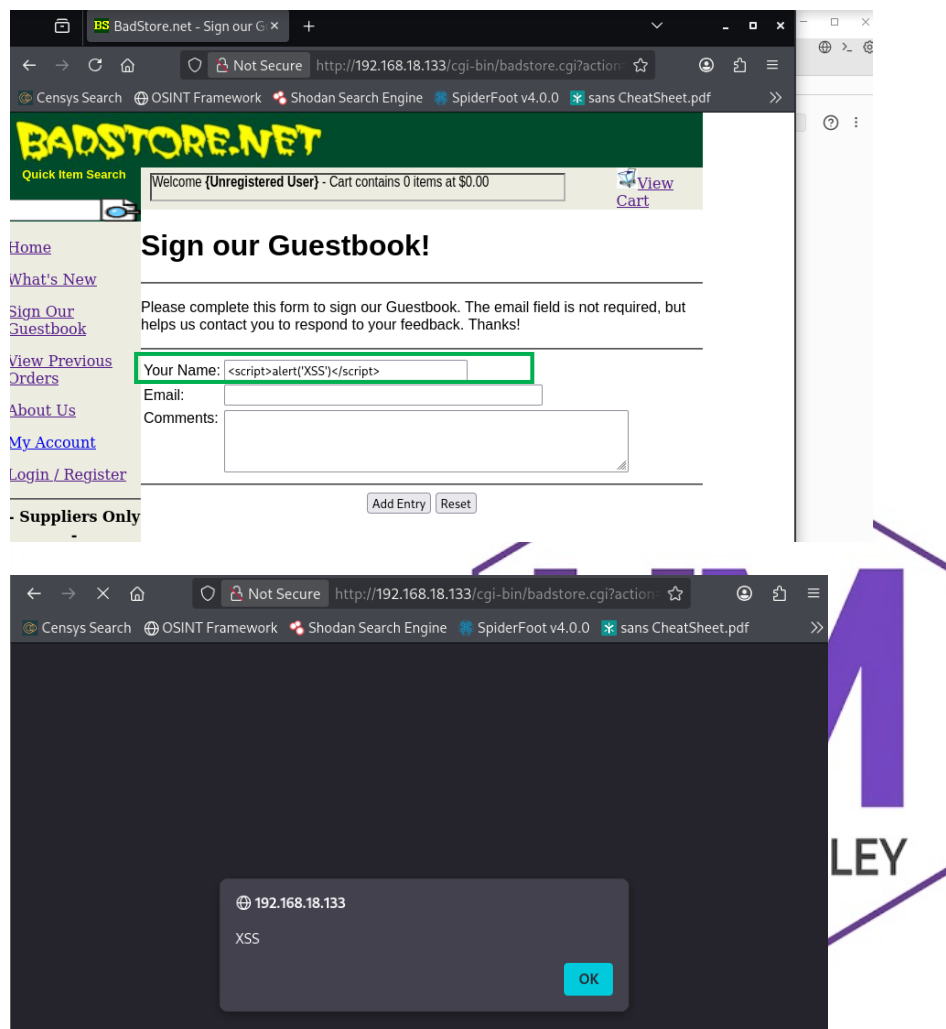


I conducted a session timeout test where I logged into the BadStore web application at 15:45 left it idle for 15 minutes and then returned to see if I was still logged in or not which I was. This is a medium risk as the session remains active indefinitely the main mitigation to this would be to implement session timeouts after a given period of the session being idle.

DO NOT COPY

6.7 INPUT VALIDATION TESTING (WSTG-INPV)

6. CVE2007-6388



The web application fails to sanitise user input which allows execution of JavaScript. Attackers could execute scripts in a victims browser potentially stealing session cookies. This vulnerability could also be used to inject malicious scripts and deliver phishing content to suppliers.

DO NOT COPY

2. Field Length Validation

The screenshot displays the BadStore.net website interface. The top navigation bar includes links for Home, What's New, Sign Our Guestbook, View Previous Orders, About Us, My Account, and Login / Register. The main content area is titled "Login to Your Account or Register for a New Account". It contains two sections: "Login to Your Account" with fields for Email Address and Password, and "Register for a New Account" with fields for Full Name, Email Address, Password, and Password Hint. The "Register for a New Account" section is highlighted with a green border. The "Full Name" field contains a long string of 'A's, and the "Email Address" field contains a long string of 'B's. The "Password" field contains a long string of dots. The "Password Hint" field is set to "green". Below the registration fields, there is a "Register" button and a note about the password hint. The bottom of the page shows the "Welcome to BadStore.net!" message and a "View Cart" link.

BADSTORE.NET
Quick Item Search

Welcome (Unregistered User) - Cart contains 0 items at \$0.00 [View Cart](#)

Login to Your Account or Register for a New Account

Login to Your Account

Email Address:

Password:

Register for a New Account

Full Name:

Email Address:

Password:

Password Hint - What's Your Favorite Color?:

(The Password Hint is used as a security measure to help recover a forgotten password. You will need both your email address and this hint to access your account if you forget your current password.)

BADSTORE.NET
Quick Item Search

Welcome AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA -
(Cart contains 0 items at \$0.00) [View Cart](#)

Welcome to BadStore.net!

There is no validation on the web application during user registration it accepts incorrectly formatted email addresses and does not have any length restrictions on the input

DO NOT COPY

1. CVE-2001-1556- Log Injection



DO NOT COPY

```
L-$ curl -H "User-Agent: normal-user" http://192.168.18.133
<HTML><HEAD><TITLE>Welcome to BadStore.net v1.2.3s</TITLE></HEAD>

<BODY bgColor=#ffffff leftMargin=0 topMargin=0 MARGINHEIGHT="0" MARGINWIDTH="0">

<TABLE cellSpacing=0 cellPadding=0 width=760 bgColor=#004b2c border=0>
  <TBODY>
    <TR>
      <TD width=326 bgColor=#004b2c>
        <IMG height=60 alt="BadStore.net" hspace=0 src="/images/BadStore.jpg"
        width=350 border=0>
      </TD></TR></TBODY></TABLE>
  <TABLE cellSpacing=0 cellPadding=0 width=760 border=0>
    <TBODY>
      <TR vAlign=top align=left>
        <TD vAlign=top width=143 bgColor=#e0e0e0>
          <TABLE cellSpacing=0 cellPadding=0 width=143 bgColor=#004b2c border=0>
            <TBODY>
              <TR>
                <TD colspan=3>
                  <FORM name=search onSubmit="/cgi-bin/badstore.cgi"
                  method=get>
                  <TBODY>
                    <TR>
                      <TD vAlign=top width=143 colSpan=3>
                        <TABLE cellSpacing=0 cellPadding=0 width=143 border=0>
                          <TBODY>
                            <TR bgColor=#004b2c>
                              <TR>
                                <TR vAlign=center bgColor=#004b2c width="138">
                                  <TD class=normal width=94 height=30><INPUT class=normal
                                  maxLength=60 size=10 name=searchquery> </TD>
                                  <font color=yellow size=2 face=Arial><Center><B>Quick Item Search</B></Center></font>
                                <TD width=44>
                                  <BR><INPUT type=hidden value='search' name='action'>
                                  <INPUT
                                  onclick="Go Search" type=image height=25 alt="Go Search"
                                  width=44
                                  src="/images/index.gif"
                                  border=0></A></TD></TR>
                                <TR bgColor=#004b2c>
                                  </TR>
                                <TR>
                                  <TD colSpan=2></TD></TR></TBODY></FORM></TABLE></TD></TR>
                                <TR bgColor=#e0e0e0>
                                  <TD class=normal width=135><BR>
                                  <A HREF="/cgi-bin/badstore.cgi">Home </A><BR>
                                  <P>
                                  <A HREF="/cgi-bin/badstore.cgi?action=whatsnew">What's New </A><BR>
                                  <P>
                                  <A HREF="/cgi-bin/badstore.cgi?action=guestbook">Sign Our Guestbook </A><BR>
                                  <P>
                                  <A HREF="/cgi-bin/badstore.cgi?action=viewprevious">View Previous Orders <BR></A>
                                  <P>
                                  <A HREF="/cgi-bin/badstore.cgi?action=aboutus">About Us </A><BR>
                                  <P>
                                  <A HREF="/cgi-bin/badstore.cgi?action=myaccount">My Account</A><BR><P>
                                  <A HREF="/cgi-bin/badstore.cgi?action=loginregister">Login / Register</A><BR>
                                  <Center><P><HR><B> Suppliers Only ~</B><P></Center>
                                  <A HREF="/cgi-bin/badstore.cgi?action=supplierlogin">Supplier
                                  Login</A><BR>
                                  <P><HR>
                                  <Center><B><1> Reference ~</B></Center><P>
                                  <A HREF="/BadStore_net_v1_2_Manual.pdf"><FONT SIZE=-2><i>BadStore.net Manual
                                  v1.2</i></FONT></A><BR>
                                  <A HREF="/scanbot/scanbot.html"></A>
                                  <P>
                                  <HR>
                                  </TD></TR>
                                <TR>
                                  <TD colspan=3>
                                  <TBODY></TABLE></TD>
                                  <TD width=1 bgColor=#e0e0e0>
                                  </TD>
                                <TD width=615>
                                  <TABLE cellSpacing=0 cellPadding=0 width=614 border=0>
                                    <TBODY>
                                      <TR>
                                        <TD bgColor=#333333></TD></TR></TBODY></TABLE>
                                  <TABLE cellSpacing=0 cellPadding=0 width=614 border=0>
                                    <TBODY>
                                      <TR bgColor=#e0e0e0></TR>
                                      <TR bgColor=#e0e0e0>
                                        <TD class=normal width=550 height=20><6nbsp;
                                        </TD>
                                      <TR>
                                        <TD class=normal width=120><IMG SRC="/images/cart.jpg"><A
                                        HREF="/cgi-bin/badstore.cgi?action=cartview">View Cart</A></TD></TR>
                                        <TR bgColor=#333333>
                                        </TR></TBODY></TABLE><FONT FACE='Arial'>

                                  <center><H1>Welcome to BadStore.net!</H1><HR><P><IMG BORDER="0" SRC="/images/store1.jpg"></center><P><HR><P><BR><Cen
                                  ter><FONT SIZE=2, FACE='Times'>BadStore v1.2.3s - Copyright 6#169; 2004-2006</Center>
```

Figure 26- Sending anormal header

DO NOT COPY

```

curl -H "User-Agent: atker@a127.0.0.1" http://192.168.18.133
<HTML><HEAD><TITLE>Welcome to BadStore.net v1.2.3</TITLE></HEAD>

<BODY bgColor=#ffffff leftMargin=0 topMargin=0 MARGINHEIGHT="0" MARGINWIDTH="0">

<TABLE cellSpacing=0 cellPadding=0 width=760 bgColor=#004b2c border=0>
<TBODY>
<TR>
<TD width=326 bgColor=#004b2c>
<IMG height=60 alt="BadStore.net" hspace=0 src="/images/BadStore.jpg" width=350 border=0>
</TD></TR><TBODY></TABLE>
<TABLE cellSpacing=0 cellPadding=0 width=760 border=0>
<TBODY>
<TR valign=top align=left>
<TD valign=top width=143 bgColor=#ecece0>
<TABLE cellSpacing=0 cellPadding=0 width=143 bgColor=#004b2c border=0>
<FORM name=search onSubmit="/cgi-bin/badstore.cgi method=get>
<TBODY>
<TR>
<TD valign=top width=143 colSpan=3>
<TABLE cellSpacing=0 cellPadding=0 width=143 border=0>
<TBODY>
<TR bgColor=#004b2c>
</TR>
<TR valign=center bgColor=#004b2c width="138">
<TD class=normal width=94 height=30>&nbsp;&nbsp;&nbsp;<INPUT class=normal maxLength=60 size=10 name=searchquery> </TD>
<TD colspan=2><input type=hidden value="search" name="action">
<INPUT
onClick="Go Search" type=image height=25 alt="Go Search" width=44
src="/images/index.gif"
border=0></A></TD></TR>
<TR bgColor=#004b2c>
</TR>
</TD>
<TD colspan=2></TD></TR><TBODY></FORM></TABLE></TD></TR>
<TR bgColor=#ecece0>
<TD colspan=2></TD></TR><TBODY></FORM></TABLE></TD></TR>
<TD class=normal width=135><BR>
<A HREF="/cgi-bin/badstore.cgi">Home </A><BR>
<P>
<A HREF="/cgi-bin/badstore.cgi?action=whatsnew">What's New </A><BR>
<P>
<A HREF="/cgi-bin/badstore.cgi?action=guestbook">Sign Our Guestbook </A><BR>
<P>
<A HREF="/cgi-bin/badstore.cgi?action=viewprevious">View Previous Orders <BR></A>
<P>
<A HREF="/cgi-bin/badstore.cgi?action=aboutus">About Us </A><BR>
<P>
<A HREF="/cgi-bin/badstore.cgi?action=myaccount">My Account</A><BR><P>
<A HREF="/cgi-bin/badstore.cgi?action=loginregister">Login / Register</A><BR>
<Center><P><HR><B> Suppliers Only </B><P></Center>
<A HREF="/cgi-bin/badstore.cgi?action=supplierlogin">Supplier
Login</A><BR>
<P><HR>
<Center><B><I> Reference </I></B></Center><P>
<A HREF="/BadStore_net_v1.2_Manual.pdf">FONT SIZE=2><I>BadStore.net Manual
v1.2</I></FONT></A><BR>
<A HREF="/scanbot/scanbot.html"></A>
<P>
<HR>
</TD></TR>
</TBODY></TABLE></TD>
<TD width=1 bgColor=#ecece0>
</TD>
<TD width=615>
<TABLE cellSpacing=0 cellPadding=0 width=614 border=0>
<TBODY>
<TR>
<TD colspan=3><TD bgColor=#333333></TD></TR><TBODY></TABLE>
<TABLE cellSpacing=0 cellPadding=0 width=614 border=0>
<TBODY>
<TR bgColor=#ecece0></TR>
<TR bgColor=#ecece0>
<TD class=normal width=550 height=20>&nbsp;&nbsp;&nbsp;</TD>
<TD colspan=2><TD class=normal width=120><IMG SRC="/images/cart.jpg"><A
HREF="/cgi-bin/badstore.cgi?action=cartview">View Cart</A></TD></TR>
<TR bgColor=#333333>
<TD colspan=3></TD></TR><TBODY></TABLE></FONT FACE="Arial">

<center><H3>Welcome to BadStore.net!</H3><HR><P><IMG BORDER="0" SRC="/images/store1.jpg"></center><P><HR><P><BR><Center><FONT SIZE=2, FACE="Times">BadStore v1.2.3s - Copyright 6#169; 2004-2006</Center>
</BODY></HTML>

```

Figure 27- Injecting a new line character %0a

DO NOT COPY

```

5 curl -H 'User-Agent: attacker@000127.0.0.1 - - [HELLO] http://192.168.18.133
<HTML><TITLE>Welcome to BadStore.net v1.2.3s</TITLE></HEAD>

<BODY bgcolor=#ffffff leftMargin=0 topMargin=0 MARGINHEIGHT="0" MARGINWIDTH="0">

<TABLE cellSpacing=0 cellPadding=0 width=760 bgcolor=#004b2c border=0>
  <TBODY>
    <TR>
      <TD width=326 bgcolor=#004b2c>
        <IMG height=60 alt="BadStore.net" hspace=0 src="/images/BadStore.jpg"
width=350
border=0>
        </TD><TR></TBODY></TABLE>
    <TABLE cellSpacing=0 cellPadding=0 width=760 border=0>
      <TBODY>
        <TR valign=top align=left>
          <TD valign=top width=143 bgcolor=#ecec00>
            <TABLE cellSpacing=0 cellPadding=0 width=143 bgcolor=#004b2c border=0>
              <FORM name=search onSubmit="/cgi-bin/badstore.cgi"
method=get>
              <TBODY>
                <TR>
                  <TD valign=top width=143 colSpan=3>
                    <TABLE cellSpacing=0 cellPadding=0 width=143 border=0>
                      <TBODY>
                        <TR bgcolor=#004b2c>
                          <TD colspan=3>
                            <TR valign=center bgcolor=#004b2c width="138">
                              <TD class=normal width=94 height=30><input type=search
maxLength=60 size=10 name=searchquery> </TD>
                              <td colspan=2>
                                <font color=yellow size=2 face=Arial><center><B>Quick Item Search</B></center></font>
                                <TD width=44>
                                  <BR><INPUT type=hidden value='search' name='action'>
                                  <INPUT
                                onlicks="Go Search" type=image height=25 alt="Go Search"
                                width=44
                                src="/images/index.gif"
                                border=0></A></TD></TR>
                                  <TR bgcolor=#004b2c>
                                    <TD colspan=3>
                                      </TD>
                                      <TD colspan=2>
                                        <TD colspan=2></TD></TR>
                                        <TR bgcolor=#ecec00>
                                          <TD colspan=3>
                                            <TD class=normal width=135><BR>

          <A HREF="/cgi-bin/badstore.cgi">Home </A><BR>
          <A HREF="/cgi-bin/badstore.cgi?action=whatsnew">What's New </A><BR>
          <A HREF="/cgi-bin/badstore.cgi?action=guestbook">Sign Our Guestbook </A><BR>
          <A HREF="/cgi-bin/badstore.cgi?action=viewprevious">View Previous Orders <BR></A>
          <A HREF="/cgi-bin/badstore.cgi?action=aboutus">About Us </A><BR>
          <A HREF="/cgi-bin/badstore.cgi?action=myaccount">My Account</A><BR><P>
          <A HREF="/cgi-bin/badstore.cgi?action=loginregister">Login / Register</A><BR>
          <A HREF="/cgi-bin/badstore.cgi?action=supplierlogin">Supplier
Login</A><BR>
          <P><HR>
          <Center><B>Reference </B></Center><P>
          <A HREF="/BadStore_net_v1.2_Manual.pdf">BadStore.net Manual
v1.2</A></FONT></A><BB>
          <A HREF="/scanbot/scanbot.html"></A>
          <P>
            <HR>
          </TD></TR>
        </TBODY></TABLE></TD>
        <TD width=1 bgcolor=#ecec00>
          <TD width=615>
            <TABLE cellSpacing=0 cellPadding=0 width=614 border=0>
              <TBODY>
                <TR>
                  <TD bgcolor=#333333></TD><TR></TBODY></TABLE>
              <TABLE cellSpacing=0 cellPadding=0 width=614 border=0>
                <TBODY>
                  <TR bgcolor=#ecec00></TR>
                  <TR bgcolor=#ecec00>
                    <TD class=normal width=550 height=20><h3>
                    </TD>
                    <TD class=normal width=120><IMG SRC="/images/cart.jpg"><A
HREF="/cgi-bin/badstore.cgi?action=cartview">View Cart</A></TD></TR>
                    <TR bgcolor=#333333>
                      <TD colspan=2>
                        <TR></TBODY></TABLE><FONT FACE="Arial">

<center><H1>Welcome to BadStore.net!</H1><HR><P><IMG BORDER="0" SRC="/images/store.jpg"></center><P><HR><P><BR><Center>
<font SIZE=2, FACE="Times" BadStore! v1.2.3s - Copyright B1699; 2004-2000</center>
</BODY></HTML>

```

Figure 28-Injecting %0d

DO NOT COPY

-V final results

```
$ curl -v -H "User-Agent: attacker@a127.0.0.1" http://192.168.18.133
* Trying 192.168.18.133:80 ...
* Established connection to 192.168.18.133 (192.168.18.133 port 80) from 192.168.18.132 port 58224
* using HTTP/1.x
> GET / HTTP/1.1
> Host: 192.168.18.133
> Accept: */*
> User-Agent: attacker@a127.0.0.1
<
* Request completely sent off
< HTTP/1.1 200 OK
< Date: Wed, 01 Apr 2006 10:16:59 GMT
< Server: Apache/1.3.28 (Unix) mod_ssl/2.8.15 OpenSSL/0.9.7c
< Last-Modified: Sun, 14 May 2006 21:16:23 GMT
< ETag: "14b-dff-44679e27"
< Accept-Ranges: bytes
< Content-Length: 3583
< Content-Type: text/html
< X-Pad: avoid browser bug
<
<HTML><HEAD><TITLE>Welcome to BadStore.net v1.2.3s</TITLE></HEAD>
<BODY bgcolor=#ffffff leftMargin=0 topMargin=0 MARGINHEIGHT="0" MARGINWIDTH="0">
<TABLE cellSpacing=0 cellPadding=0 width=760 bgcolor=#004b2c border=0>
<TBODY>
<TR>
<TD width=326 bgcolor=#004b2c>
<IMG height=60 alt="BadStore.net" hspace=0 src="/images/BadStore.jpg" width=350 border=0>
</TD><TR><TD></TD></TR>
<TABLE cellSpacing=0 cellPadding=0 width=760 border=0>
<TBODY>
<TR valign=top align=left>
<TD valign=top width=143 bgcolor=#ececec>
<TABLE cellSpacing=0 cellPadding=0 width=143 bgcolor=#004b2c border=0>
<FORM name=search onSubmit=/cgi-bin/badstore.cgi method=get>
<TBODY>
<TR>
<TD valign=top width=143 colSpan=3>
<TABLE cellSpacing=0 cellPadding=0 width=143 border=0>
<TBODY>
<TR bgcolor=#004b2c>
</TR>
<TR align=center bgcolor=#004b2c width="138">
<TD class=normal width=94 height=30>&nbsp;<INPUT class=normal maxLength=60 size=10 name=searchquery> </TD>
<font color=yellow size=2 face=Arial><Center><B>Quick Item Search</B></Center></font>
<TD width=44>
<BR><INPUT type=hidden value='search' name='action'>
<INPUT
onClick="Go Search" type=image height=25 alt="Go Search" width=44
src="/images/index.gif"
border=0></A></TD></TR>
<TR bgcolor=#004b2c>
</TR>
<TR>
<TD colSpan=2></TD></TR><TD></TD></TR>
<TR bgcolor=#ececec>
<TD class=normal width=135><BR>
<A HREF="/cgi-bin/badstore.cgi">Home </A><BR>
<A HREF="/cgi-bin/badstore.cgi?action=whatsnew">What's New </A><BR>
<A HREF="/cgi-bin/badstore.cgi?action=guestbook">Sign Our Guestbook </A><BR>
<A HREF="/cgi-bin/badstore.cgi?action=viewprevious">View Previous Orders <BR></A>
<A HREF="/cgi-bin/badstore.cgi?action=abouts">>About Us </A><BR>
<A HREF="/cgi-bin/badstore.cgi?action=myaccount">My Account</A><BR><P>
<A HREF="/cgi-bin/badstore.cgi?action=loginregister">Login / Register</A><BR>
<A HREF="/cgi-bin/badstore.cgi?action=supplierlogin">Supplier Login</A><BR>
<P><HR>
<Center><B><i>- Reference -</i></B></Center><p>
<A HREF="/BadStore_net_v1_2_Manual.pdf"><i>BadStore.net Manual v1.2</i></A><BR>
<A HREF="/scanbot/scanbot.html"></A>
<P>
<HR>
<Reference>
</TD></TR>
</TBODY></TABLE></TD>
<TD width=1 bgColor=#ececec>
</TD>
<TD width=615>
<TABLE cellSpacing=0 cellPadding=0 width=614 border=0>
```

DO NOT COPY

```
<TBODY>
<TR bgcolor=#ecec00></TR>
<TR bgcolor=#ecec00>
  <TD class=normal width=550 height=20>&nbsp;&nbsp;&nbsp;&nbsp;&nbsp;&nbsp;&nbsp;&nbsp;&nbsp;&nbsp;&
    <TD class=normal width=120><IMG SRC="/images/cart.jpg"><A
HREF="/cgi-bin/badstore.cgi?action=cartview">View Cart</A></TD></TR>
<TR bgcolor=#333333>
  </TR></TBODY></TABLE><FONT FACE='Arial'>

<center><H1>Welcome to BadStore.net!</H1><HR><P><IMG BORDER="0" SRC="/images/store1.jpg"></center><P><HR><P><BR><Center><FONT SIZE=2, FACE='Times'>BadStore v1.2.3s - Copyright 6#169; 2004-2006</Center>
</BODY></HTML>
* Connection #0 to host 192.168.18.133:80 left intact
```

Figure 29- - V Results

My testing confirmed that unsensitised control characters can be injected into HTTP headers, potentially enabling log poisoning attacks.

2. CVE 2005-3352- Referer Header XSS



DO NOT COPY

```
* curl -v -H "Referer: http://google.com" http://192.168.18.133
* Trying 192.168.18.133:80 ...
* Established connection to 192.168.18.133 (192.168.18.133 port 80) from 192.168.18.132 port 46938
* using HTTP/1.x
> GET / HTTP/1.1
> Host: 192.168.18.133
> User-Agent: curl/8.18.0
> Accept: */*
> Referer: http://google.com
>
* Request completely sent off
< HTTP/1.1 200 OK
< Date: Wed, 01 Apr 2026 18:36:26 GMT
< Server: Apache/1.3.28 (Unix) mod_ssl/2.8.15 OpenSSL/0.9.7c
< Last-Modified: Sun, 14 May 2006 21:16:23 GMT
< ETag: "14b-dff-44679e27"
< Accept-Ranges: bytes
< Content-Length: 3583
< Content-Type: text/html
< X-Pad: avoid browser bug
<
<HTML><HEAD><TITLE>Welcome to BadStore.net v1.2.3s</TITLE></HEAD>
<
<BODY bgColor=#ffffff leftMargin=0 topMargin=0 MARGINHEIGHT="0" MARGINWIDTH="0">
<
<TABLE cellSpacing=0 cellPadding=0 width=760 bgColor=#004b2c border=0>
<TBODY>
<TR>
<TD width=326 bgColor=#004b2c>
<IMG height=60 alt="BadStore.net" hspace=0 src="/images/BadStore.jpg"
width=350
border=0>
</TD></TR><TBODY></TABLE>
<TABLE cellSpacing=0 cellPadding=0 width=760 border=0>
<TBODY>
<TR valign=top align=left>
<TD width=top width=143 bgColor=#ecec0>
<TABLE cellSpacing=0 cellPadding=0 width=143 bgColor=#004b2c border=0>
<FORM name=search onsubmit="/cgi-bin/badstore.cgi
method=get>
<TBODY>
<TR>
<TD valign=top width=143 colSpan=3>
<TABLE cellSpacing=0 cellPadding=0 width=143 border=0>
<TBODY>
<TR bgColor=#004b2c>
</TR>
<TD colSpan=2></TD></TR><TBODY></FORM></TABLE></TD></TR>
<TR bgColor=#ecec0>
<TD class=normal width=135><BR>
<A HREF="/cgi-bin/badstore.cgi">Home </A><BR>
<P>
<A HREF="/cgi-bin/badstore.cgi?action=whatsnew">What's New </A><BR>
<P>
<A HREF="/cgi-bin/badstore.cgi?action=guestbook">Sign Our Guestbook </A><BR>
<P>
<A HREF="/cgi-bin/badstore.cgi?action=viewprevious">View Previous Orders <BR></A>
<P>
<A HREF="/cgi-bin/badstore.cgi?action=aboutus">About Us </A><BR>
<P>
<A HREF="/cgi-bin/badstore.cgi?action=myaccount">My Account</A><BR><P>
<A HREF="/cgi-bin/badstore.cgi?action=loginregister">Login / Register</A><BR>
<Center><P><HR><B> Suppliers Only </B><P></Center>
<A HREF="/cgi-bin/badstore.cgi?action=supplierlogin">Supplier
Login</A><BR>
<P><HR>
<Center><B><i> Reference </i></B></Center><P>
<A HREF="/BadStore_net_v1_2_Manual.pdf"><FONT SIZE=-2><i>BadStore.net Manual
v1.2</i></FONT></A><BR>
<A HREF="/scanbot/scanbot.html"></A>
<P>
<HR>
</TD></TR>
</TBODY></TABLE></TD>
<TD width=1 bgColor=#ecec0>
</TD>
<TD width=615>
<TABLE cellSpacing=0 cellPadding=0 width=614 border=0>
<TBODY>
<TR>
<TD bgColor=#333333></TD></TR><TBODY></TABLE>
<TABLE cellSpacing=0 cellPadding=0 width=614 border=0>
<TBODY>
<TR bgColor=#ecec0></TR>
<TR bgColor=#ecec0>
<TD class=normal width=550 height=20>bnbsp;
</TD>
<TD class=normal width=120><IMG SRC="/images/cart.jpg"><A
HREF="/cgi-bin/badstore.cgi?action=cartview">View Cart</A></TD></TR>
<TR bgColor=#333333>
</TR></TBODY></TABLE></FONT FACE="Arial">
<
<center><H1>Welcome to BadStore.net!</H1><HR><P><IMG BORDER="0" SRC="/images/store1.jpg"></center><P><HR><P><BR><Ce
nter><FONT SIZE=2, FACE="Times">BadStore v1.2.3s - Copyright 8169; 2004-2006</Center>
</BODY></HTML>
* Connection #0 to host 192.168.18.133:80 left intact
```

Figure 30- These tests focused on the manipulation of HTTP headers to identify improper input sanitisation.

DO NOT COPY

```

[~] (kali@kali) [-]
[*] curl -v -H "Referer: test123" http://192.168.18.133
* Trying 192.168.18.133:80...
* Established connection to 192.168.18.133 (192.168.18.133 port 80) from 192.168.18.132 port 33418
* using HTTP/1.x
* GET / HTTP/1.1
> Host: 192.168.18.133
> User-Agent: curl/8.18.0
> Accept: */*
> Referer: test123
>
* Request completely sent off
< HTTP/1.1 200 OK
< Date: Wed, 01 Apr 2026 10:46:58 GMT
< Server: Apache/1.3.28 (Unix) mod_ssl/2.8.15 OpenSSL/0.9.7c
< Last-Modified: Sun, 14 May 2006 21:16:23 GMT
< ETag: "14b-dff-44679e27"
< Accept-Ranges: bytes
< Content-Length: 3583
< Content-Type: text/html
< X-Pad: avoid browser bug
<
<HTML><HEAD><TITLE>Welcome to BadStore.net v1.2.3s</TITLE></HEAD>
<BODY bgColor=#ffffff leftMargin=0 topMargin=0 MARGINHEIGHT="0" MARGINWIDTH="0">
<TABLE cellSpacing=0 cellPadding=0 width=760 bgColor=#004b2c border=0>
<TBODY>
<TR>
<TD width=326 bgColor=#004b2c>
<IMG height=60 alt="BadStore.net" hspace=0 src="/images/BadStore.jpg"
width=350
border=0>
</TD></TR><TBODY></TABLE>
<TABLE cellSpacing=0 cellPadding=0 width=760 border=0>
<TBODY>
<TR vAlign=top align=left>
<TD vAlign=top width=143 bgColor=#ecec00>
<TABLE cellSpacing=0 cellPadding=0 width=143 bgColor=#004b2c border=0>
<FORM name=search onsubmit="/cgi-bin/badstore.cgi
method=get>
<TBODY>
<TR>
<TD vAlign=top width=143 colSpan=3>
<TABLE cellSpacing=0 cellPadding=0 width=143 border=0>
<TBODY>
<TR bgColor=#004b2c>
<A HREF="/cgi-bin/badstore.cgi?action=whatsnew">What's New </A><BR>
<P>
<A HREF="/cgi-bin/badstore.cgi?action=guestbook">Sign Our Guestbook </A><BR>
<P>
<A HREF="/cgi-bin/badstore.cgi?action=viewprevious">View Previous Orders <BR></A>
<P>
<A HREF="/cgi-bin/badstore.cgi?action=aboutus">About Us </A><BR>
<P>
<A HREF="/cgi-bin/badstore.cgi?action=myaccount">My Account</A><BR><P>
<A HREF="/cgi-bin/badstore.cgi?action=loginregister">Login / Register</A><BR>
<Center><P><HR><B> Suppliers Only </B><P></Center>
<A HREF="/cgi-bin/badstore.cgi?action=supplierlogin">Supplier
Login</A><BR>
<P><HR>
<Center><B><i> Reference </i></B></Center><P>
<A HREF="/BadStore_net_v1_2_Manual.pdf"><FONT SIZE=-2><i>BadStore.net Manual
v1.2</i></FONT></A><BR>
<A HREF="/scanbot/scanbot.html"></A>
<P>
<HR>
</TD></TR>
</TBODY></TABLE></TD>
<TD width=1 bgColor=#ecec00>
</TD>
<TD width=615>
<TABLE cellSpacing=0 cellPadding=0 width=614 border=0>
<TBODY>
<TR>
<TD bgColor=#333333></TD></TR><TBODY></TABLE>
<TABLE cellSpacing=0 cellPadding=0 width=614 border=0>
<TBODY>
<TR bgColor=#ecec00></TR>
<TR bgColor=#ecec00>
<TD class=normal width=550 height=20>6nbsp;
</TD>
<TD class=normal width=120><IMG SRC="/images/cart.jpg"><A
HREF="/cgi-bin/badstore.cgi?action=cartview">View Cart</A></TD></TR>
<TR bgColor=#333333>
</TR></TBODY></TABLE><FONT FACE='Arial'>
<center><H1>Welcome to BadStore.net!</H1><HR><P><IMG BORDER="0" SRC="/images/store1.jpg"></center><P><HR><P><BR><center>
nter><FONT SIZE=2, FACE='Times'>BadStore v1.2.3s - Copyright 6#169; 2004-2006</center>
</BODY></HTML>
* Connection #0 to host 192.168.18.133:80 left intact

```

Figure 31- These tests show the referrer header accepted unsensitised input without any form of validation this indicates potential attack surface for potential exploitation

An XSS payload (`<script>alert('XSS') </script>`) was injected into the referrer header when the request was processed the payload was accepted without sensitisation. This vulnerability is critical because it allows execution of attacker controlled JavaScript in the victim's browser which enables session hijacking through cookie theft.

3. CVE 2006-3918- Expect Header XSS

Sending a normal header

```
$ curl -v -H "Expect: 100-continue" http://192.168.18.133
* Trying 192.168.18.133:80...
* Established connection to 192.168.18.133 (192.168.18.133 port 80) from 192.168.18.132 port 60230
* using HTTP/1.x
> GET / HTTP/1.1
> Host: 192.168.18.133
> User-Agent: curl/8.18.0
> Accept: */*
> Expect: 100-continue
>
* Request completely sent off
< HTTP/1.1 200 OK
< Date: Wed, 01 Apr 2026 11:01:15 GMT
< Server: Apache/1.3.28 (Unix) mod_ssl/2.8.15 OpenSSL/0.9.7c
< Last-Modified: Sun, 14 May 2006 21:16:23 GMT
< ETag: "14b-dff-44679e27"
< Accept-Ranges: bytes
< Content-Length: 3583
< Content-Type: text/html
< X-Pad: avoid browser bug
<
<HTML><HEAD><TITLE>Welcome to BadStore.net!</TITLE></HEAD>
<BODY bgcolor=#ffffff leftMargin=0 topMargin=0 MARGINHEIGHT="0" MARGINWIDTH="0">
<TABLE cellSpacing=0 cellPadding=0 width=760 bgcolor=#004b2c border=0>
<TBODY>
<TR>
<TD width=326 bgcolor=#004b2c>
<IMG height=60 alt="BadStore.net" hspace=0 src="/images/BadStore.jpg"
width=350
border=0>
</TD></TR></TBODY></TABLE>
<TABLE cellSpacing=0 cellPadding=0 width=760 border=0>
<TBODY>
<TR valign=top align=left>
<TD valign=top width=143 bgcolor=#e0e0e0>
<TABLE cellSpacing=0 cellPadding=0 width=143 bgcolor=#004b2c border=0>
<FORM name=search onSubmit="/cgi-bin/badstore.cgi
method=get>
<TBODY>
<TR>
<TD valign=top width=143 colSpan=3>
<TABLE cellSpacing=0 cellPadding=0 width=143 border=0>
<TBODY>
<TR bgcolor=#004b2c>
maxlength=60 size=10 name=searchquery> </TD>
<font color=yellow size=2 face=Arial><Center><B>Quick Item Search</B></Center></font>
<TD width=44>
<BR><INPUT type=hidden value=search' name='action'>
<INPUT
onClick="Go Search" type=image height=25 alt="Go Search"
width=44
src="/images/index.gif"
border=0></A></TD></TR>
<TR bgcolor=#004b2c>
</TR>
<TR>
<TD colSpan=2></TD></TR></TBODY></TABLE></TD></TR>
<TR bgcolor=#e0e0e0>
<TD class=normal width=135><BR>
<A HREF="/cgi-bin/badstore.cgi">Home </A><BR>
<P>
<A HREF="/cgi-bin/badstore.cgi?action=whatsnew">What's New </A><BR>
<P>
<A HREF="/cgi-bin/badstore.cgi?action=guestbook">Sign Our Guestbook </A><BR>
<P>
<A HREF="/cgi-bin/badstore.cgi?action=viewprevious">View Previous Orders <BR></A>
<P>
<A HREF="/cgi-bin/badstore.cgi?action=aboutus">About Us </A><BR>
<P>
<A HREF="/cgi-bin/badstore.cgi?action=myaccount">My Account</A><BR><P>
<A HREF="/cgi-bin/badstore.cgi?action=loginregister">Login / Register</A><BR>
<Center><B><HR><B> Suppliers Only </B></Center>
<A HREF="/cgi-bin/badstore.cgi?action=supplierlogin">Supplier
Login</A><BR>
<P><HR>
<Center><B><i> Reference </i></B></Center><p>
<A HREF="/BadStore_net_v1_2_Manual.pdf"><FONT SIZE=-2><i>BadStore.net Manual
v1.2</i></FONT></A><BR>
<A HREF="/scanbot/scanbot.html"></A>
<P>
<HR>
</TD></TR>
</TBODY></TABLE></TD>
<TD width=1 bgcolor=#e0e0e0>
</TD>
<TD width=15>
<TABLE cellSpacing=0 cellPadding=0 width=614 border=0>
<TBODY>
<TR bgcolor=#e0e0e0></TR>
<TR bgcolor=#e0e0e0>
<TD class=normal width=550 height=20>6nbsp;
</TD>
<TD class=normal width=120><IMG SRC="/images/cart.jpg"><A
HREF="/cgi-bin/badstore.cgi?action=cartview">View Cart</A></TD></TR>
<TR bgcolor=#333333>
</TR></TBODY></TABLE><FONT FACE='Arial'>
```

Figure 32- The sending of a normal header

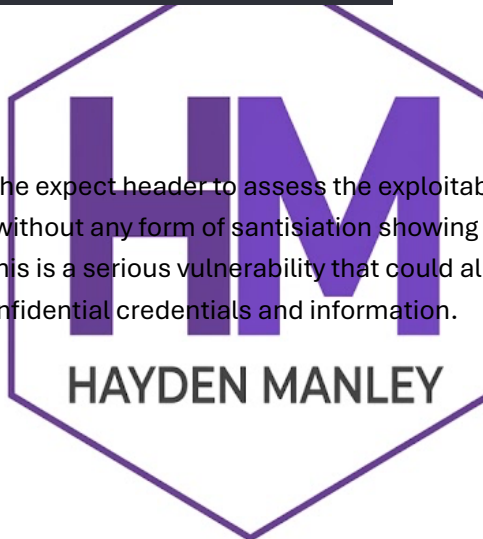
DO NOT COPY

Injecting xxs payload

```
(kali@kali)-[~]
$ curl -v -H "Expect: <script>alert(1)</script>" http://192.168.18.133
* Trying 192.168.18.133:80 ...
* Established connection to 192.168.18.133 (192.168.18.133 port 80) from 192.168.18.132 port 56952
* using HTTP/1.x
> GET / HTTP/1.1
> Host: 192.168.18.133
> User-Agent: curl/8.18.0
> Accept: */*
> Expect: <script>alert(1)</script>
>
* Request completely sent off
< HTTP/1.1 417 Expectation Failed
< Date: Wed, 01 Apr 2026 11:04:18 GMT
< Server: Apache/1.3.28 (Unix) mod_ssl/2.8.15 OpenSSL/0.9.7c
< Transfer-Encoding: chunked
< Content-Type: text/html; charset=iso-8859-1
<
<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<HTML><HEAD>
<TITLE>417 Expectation Failed</TITLE>
</HEAD><BODY>
<H1>Expectation Failed</H1>
The expectation given in the Expect request-header
field could not be met by this server.<P>
The client sent<PRE>
Expect: <script>alert(1)</script>
</PRE>
but we only allow the 100-continue expectation.
<HR>
<ADDRESS>Apache/1.3.28 Server at 192.168.18.133 Port 80</ADDRESS>
</BODY></HTML>
* Connection #0 to host 192.168.18.133:80 left intact
```

Figure 33- Injecting XSS Payload

A XSS payload was also injected into the expect header to assess the exploitability. It turns out after my testing the application accepted the input again without any form of sanitisation showing very clear lack of validation of HTTP headers within the web application. This is a serious vulnerability that could allow attackers to execute any malicious script they wish stealing confidential credentials and information.



DO NOT COPY

4. CVE- 2006-5752- Apache mod_status XSS

Check /server-status exists

```
(kali㉿kali)-[~]  
$ curl -v http://192.168.18.133/server-status  
* Trying 192.168.18.133:80 ...  
* Established connection to 192.168.18.133 (192.168.18.133 port 80) from 192.168.18.132 port 53110  
* using HTTP/1.x  
> GET /server-status HTTP/1.1  
> Host: 192.168.18.133  
> User-Agent: curl/8.18.0  
> Accept: */*  
>  
* Request completely sent off  
< HTTP/1.1 404 Not Found  
< Date: Fri, 03 Apr 2026 09:43:11 GMT  
< Server: Apache/1.3.28 (Unix) mod_ssl/2.8.15 OpenSSL/0.9.7c  
< Transfer-Encoding: chunked  
< Content-Type: text/html; charset=iso-8859-1  
<  
<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">  
<HTML><HEAD>  
<TITLE>404 Not Found</TITLE>  
</HEAD><BODY>  
<H1>Not Found</H1>  
The requested URL /server-status was not found on this server.<P>  
<HR>  
<ADDRESS>Apache/1.3.28 Server at 192.168.18.133 Port 80</ADDRESS>  
</BODY></HTML>  
* Connection #0 to host 192.168.18.133:80 left intact
```

HAYDEN MANLEY

Inject xxs payload

DO NOT COPY

```
(kali㉿kali)-[~]
$ curl -v -H "User-Agent: <script>alert(1)</script>" http://192.168.18.133/server-status
* Trying 192.168.18.133:80 ...
* Established connection to 192.168.18.133 (192.168.18.133 port 80) from 192.168.18.132 port 40736
* using HTTP/1.x
> GET /server-status HTTP/1.1
> Host: 192.168.18.133
> Accept: */*
> User-Agent: <script>alert(1)</script>
>
* Request completely sent off
< HTTP/1.1 404 Not Found
< Date: Fri, 03 Apr 2026 09:48:32 GMT
< Server: Apache/1.3.28 (Unix) mod_ssl/2.8.15 OpenSSL/0.9.7c
< Transfer-Encoding: chunked
< Content-Type: text/html; charset=iso-8859-1
<
<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<HTML><HEAD>
<TITLE>404 Not Found</TITLE>
</HEAD><BODY>
<H1>Not Found</H1>
The requested URL /server-status was not found on this server.<P>
<HR>
<ADDRESS>Apache/1.3.28 Server at 192.168.18.133 Port 80</ADDRESS>
</BODY></HTML>
* Connection #0 to host 192.168.18.133:80 left intact
```



Referrer injection

```
(kali㉿kali)-[~]
$ curl -v -H "Referer: <script>alert(1)</script>" http://192.168.18.133/server-status
* Trying 192.168.18.133:80 ...
* Established connection to 192.168.18.133 (192.168.18.133 port 80) from 192.168.18.132 port 37324
* using HTTP/1.x
> GET /server-status HTTP/1.1
> Host: 192.168.18.133
> User-Agent: curl/8.18.0
> Accept: */*
> Referer: <script>alert(1)</script>
>
* Request completely sent off
< HTTP/1.1 404 Not Found
< Date: Fri, 03 Apr 2026 09:50:04 GMT
< Server: Apache/1.3.28 (Unix) mod_ssl/2.8.15 OpenSSL/0.9.7c
< Transfer-Encoding: chunked
< Content-Type: text/html; charset=iso-8859-1
<
<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<HTML><HEAD>
<TITLE>404 Not Found</TITLE>
</HEAD><BODY>
<H1>Not Found</H1>
The requested URL /server-status was not found on this server.<P>
<HR>
<ADDRESS>Apache/1.3.28 Server at 192.168.18.133 Port 80</ADDRESS>
</BODY></HTML>
* Connection #0 to host 192.168.18.133:80 left intact
```

Save output

DO NOT COPY

```
(kali@kali)-[~]
$ curl -H "User-Agent: TESTSTATUS123" http://192.168.18.133/server-status -o status.html
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           %         %         Dload  Upload  Total   Spent    Left   Speed
100      278    0     278    0         0  76164      0         0         0
```

The server-status endpoint was not accessible, indicating there is less exposure to this vulnerability. It seems it was restricted by HTTP 403 which also suggests that the mod_status module is present but is access-controlled.

5. CVE-2007-5000 Mod_imap/mod_imagemap XSS

Looking for parameters



DO NOT COPY

```
l-$ curl http://192.168.18.133
<HTML><HEAD><TITLE>Welcome to BadStore.net v1.2.3s</TITLE></HEAD>

<BODY bgColor=#ffffff leftMargin=0 topMargin=0 MARGINHEIGHT="0" MARGINWIDTH="0">

<TABLE cellSpacing=0 cellPadding=0 width=760 bgColor=#004b2c border=0>
  <TBODY>
    <TR>
      <TD width=326 bgColor=#004b2c>
        <IMG height=60 alt="BadStore.net" hspace=0 src="/images/BadStore.jpg"
width=350 border=0>
      </TD></TR></TBODY></TABLE>
<TABLE cellSpacing=0 cellPadding=0 width=760 border=0>
  <TBODY>
    <TR valign=top align=left>
      <TD valign=top width=143 bgColor=#e0e0e0>
        <TABLE cellSpacing=0 cellPadding=0 width=143 bgColor=#004b2c border=0>
          <FORM name=search onsubmit="/cgi-bin/badstore.cgi
method=get>
          <TBODY>
            <TR>
              <TD valign=top width=143 colSpan=3>
                <TABLE cellSpacing=0 cellPadding=0 width=143 border=0>
                  <TBODY>
                    <TR bgColor=#004b2c>
                      </TR>
                    <TR valign=center bgColor=#004b2c width="138">
                      <TD class=normal width=94 height=30><input class=normal
maxLength=60 size=10 name=searchquery> </TD>
                      <TD width=44>
                        <font color=yellow size=2 face=Arial><Center><B>Quick Item Search</B></Center></font>
                      </TD>
                    </TR>
                    <TR>
                      <TD colspan=3>
                        <BR><input type=hidden value='search' name='action'>
                        <input
onclick="Go Search" type=image height=25 alt="Go Search"
width=44
src="/images/index.gif"
border=0></A></TD></TR>
                    <TR bgColor=#004b2c>
                      </TR>
                    <TR>
                      <TD colSpan=2></TD></TR></TBODY></FORM></TABLE></TD></TR>
      <TR bgColor=#e0e0e0>
        <TD class=normal width=135><BR>
          <A HREF="/cgi-bin/badstore.cgi">Home </A><BR>
          <P>
```

```
<A HREF="/cgi-bin/badstore.cgi?action=whatsnew">What's New </A><BR>
<P>
<A HREF="/cgi-bin/badstore.cgi?action=guestbook">Sign Our Guestbook </A><BR>
<P>
<A HREF="/cgi-bin/badstore.cgi?action=viewprevious">View Previous Orders <BR></A>
<P>
<A HREF="/cgi-bin/badstore.cgi?action=aboutus">About Us </A><BR>
<P>
<A HREF="/cgi-bin/badstore.cgi?action=myaccount">My Account</A><BR><P>
<A HREF="/cgi-bin/badstore.cgi?action=loginregister">Login / Register</A><BR>
<center><P><HR><B> Suppliers Only </B><P></center>
<A HREF="/cgi-bin/badstore.cgi?action=supplierlogin">Supplier
Login</A><BR>
<P><HR>
<center><B><i>- Reference -</i></B></center><P>
<A HREF="/BadStore_net_v1_2_Manual.pdf"><FONT SIZE=-2><i>BadStore.net Manual
v1.2</i></FONT></A><BR>
<A HREF="/scanbot/scanbot.html"></A>
<P>
<HR>
</TD></TR>

</TBODY></TABLE></TD>
<TD width=1 bgColor=#e0e0e0>
  </TD>
<TD width=615>
  <TABLE cellSpacing=0 cellPadding=0 width=614 border=0>
    <TBODY>
      <TR>
        <TD bgColor=#333333></TD></TR></TBODY></TABLE>
      <TABLE cellSpacing=0 cellPadding=0 width=614 border=0>
        <TBODY>
          <TR bgColor=#e0e0e0></TR>
          <TR bgColor=#e0e0e0>
            <TD class=normal width=550 height=20><BR>
            </TD>
            <TD class=normal width=120><IMG SRC="/images/cart.jpg"><A
HREF="/cgi-bin/badstore.cgi?action=cartview">View Cart</A></TD></TR>
          <TR bgColor=#333333>
            </TR></TBODY></TABLE><FONT FACE='Arial'>

<center><H1>Welcome to BadStore.net!</H1><HR><P><IMG BORDER="0" SRC="/images/store1.jpg"></center><P><HR><P><BR><Ce
nter><FONT SIZE=2, FACE='Times'>BadStore v1.2.3s - Copyright 8#169; 2004-2006</Center>
</BODY></HTML>
```

DO NOT COPY

Injecting XSS Payload

```

[~]kali@kali:~$ curl "http://192.168.18.133/?input=\"<<script>alert(1)</script>\""
<HTML><HEAD><TITLE>Welcome to BadStore.net v1.2.3s</TITLE></HEAD>

<BODY bgColor=#ffffff leftMargin=0 topMargin=0 MARGINHEIGHT="0" MARGINWIDTH="0">

<TABLE cellSpacing=0 cellPadding=0 width=760 bgColor=#004b2c border=0>
  <TBODY>
    <TR>
      <TD width=326 bgColor=#004b2c>
        <IMG height=60 alt="BadStore.net" hspace=0 src="/images/BadStore.jpg"
width=350
border=0>
      </TD></TR></TBODY></TABLE>
<TABLE cellSpacing=0 cellPadding=0 width=760 border=0>
  <TBODY>
    <TR valign=top align=left>
      <TD valign=top width=143 bgColor=#ecec00>
        <TABLE cellSpacing=0 cellPadding=0 width=143 bgColor=#004b2c border=0>
          <TBODY>
            <TR>
              <TD>
                <FORM name=search onsubmit="/cgi-bin/badstore.cgi
method=get>
                <TBODY>
                  <TR>
                    <TD valign=top width=143 colSpan=3>
                      <TABLE cellSpacing=0 cellPadding=0 width=143 border=0>
                        <TBODY>
                          <TR bgColor=#004b2c>
                            </TR>
                          <TR>
                            <TD align=center bgColor=#004b2c width="138">
                              <TD class=normal width=94 height=30>&nbsp;<INPUT class=normal
maxLength=60 size=10 name=searchquery> </TD>
                              <font color=yellow size=2 face=Arial><Center><B>Quick Item Search</B></Center></font>
                              <TD width=44>
                                <BR><INPUT type=hidden value='search' name='action'>
                                <INPUT
onclick="Go Search" type=image height=25 alt="Go Search"
width=44
src="/images/index.gif"
border=0></A></TD></TR>
                              <TR bgColor=#004b2c>
                                </TR>
                              <TR>
                                <TD colSpan=2></TD></TR></TBODY></FORM></TABLE></TD></TR>
                                <TR bgColor=#ecec00>
                                  <TD class=normal width=135><BR>
                                  <A HREF="/cgi-bin/badstore.cgi">Home </A><BR>
                                  <P>
                                  <A HREF="/cgi-bin/badstore.cgi?action=whatsnew">What's New </A><BR>
                                  <P>
                                  <A HREF="/cgi-bin/badstore.cgi?action=guestbook">Sign Our Guestbook </A><BR>
                                  <P>
                                  <A HREF="/cgi-bin/badstore.cgi?action=viewprevious">View Previous Orders <BR></A>
                                  <P>
                                  <A HREF="/cgi-bin/badstore.cgi?action=aboutus">About Us </A><BR>
                                  <P>
                                  <A HREF="/cgi-bin/badstore.cgi?action=myaccount">My Account</A><BR><P>
                                  <A HREF="/cgi-bin/badstore.cgi?action=loginregister">Login / Register</A><BR>
                                  <Center><P><HR><B> Suppliers Only </B><P></Center>
                                  <A HREF="/cgi-bin/badstore.cgi?action=supplierlogin">Supplier
Login</A><BR>
                                  <P><HR>
                                  <Center><B><i> Reference </i></B></Center><p>
                                  <A HREF="/BadStore_net_v1.2_Manual.pdf"><FONT SIZE=-2><i>BadStore.net Manual
v1.2</i></FONT></A><BR>
                                  <A HREF="/scanbot/scanbot.html"></A>
                                  <P>
                                  <HR>
                                  </TD></TR>
                                </TBODY></TABLE></TD>
                                <TD width=1 bgColor=#ecec00>
                                  </TD>
                                <TD width=615>
                                  <TABLE cellSpacing=0 cellPadding=0 width=614 border=0>
                                    <TBODY>
                                      <TR>
                                        <TD bgColor=#333333></TD></TR></TBODY></TABLE>
                                      <TABLE cellSpacing=0 cellPadding=0 width=614 border=0>
                                        <TBODY>
                                          <TR bgColor=#ecec00></TR>
                                          <TR bgColor=#ecec00>
                                            <TD class=normal width=550 height=20>&nbsp;<
                                            </TD>
                                            <TD class=normal width=120><IMG SRC="/images/cart.jpg"><A
HREF="/cgi-bin/badstore.cgi?action=cartview">View Cart</A></TD></TR>
                                            <TR bgColor=#333333>
                                              </TR></TBODY></TABLE><FONT FACE='Arial'>
<center><H1>Welcome to BadStore.net!</H1><HR><P><IMG BORDER="0" SRC="/images/store1.jpg"></center><P><HR><P><BR><Ce
nter><FONT SIZE=2, FACE='Times'>BadStore v1.2.3s - Copyright ©1999; 2004-2006</Center>
</BODY></HTML>

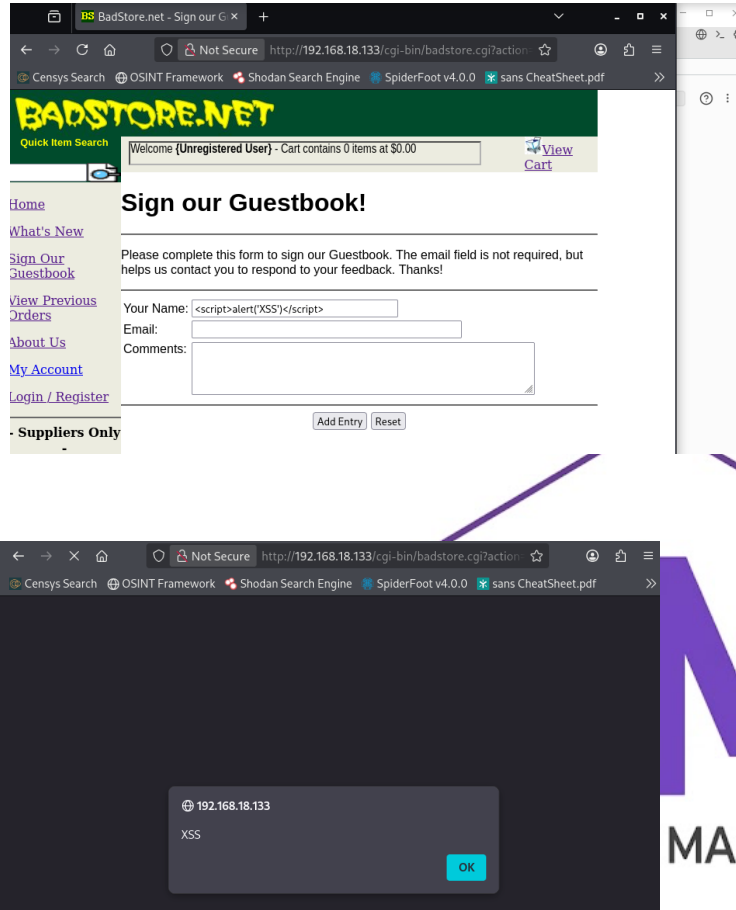
```

Figure 34 Injecting XXS Payload

I successfully injected the payload in the URL request however I didn't seem to have any execution of the JavaScript, this indicates the input was accepted but to was not reflected as an executable script.

DO NOT COPY

6. CVE2007-6388



The web application fails to sanitise user input which allows execution of JavaScript. Attackers could execute malicious scripts in a victim's browser potentially stealing session cookies, credentials and data.. This vulnerability aligns with CVE 2007-6388 demonstrating improper input validation leading to XSS. This CVE could be mitigated by implementing input validation so users can only enter numbers and letters.

6.8 TESTING FOR ERROR HANDLING (WSTG-ERR)

In figure 15 (Step 2Nikto scan results) Automated scanning using nikto revealed that the server discloses detailed version information which is Apache 2.2.3. This indicates improper error handling and configuration details like this should not be exposed to users. There is also exposure of sensitive endpoints such as /server-status this is publicly accessible exposing internal server information which increases the attack surface and relates to CVE-2006-5752. Finally, there is also a lack of security headers which suggests the web application doesn't handle http responses securely.

DO NOT COPY

As shown in figure 17 (Step 2 ZAP scan) the web application returns detailed http responses when errors occur. Once a error 404 is triggered the server returns detailed response headers including the server version and backend technology PHP/5.5x. This indicates improper error handling as sensitive information is disclosed to the user.

6.9 TESTING FOR WEAK CRYPTOGRAPHY (WSTG-CRYP)

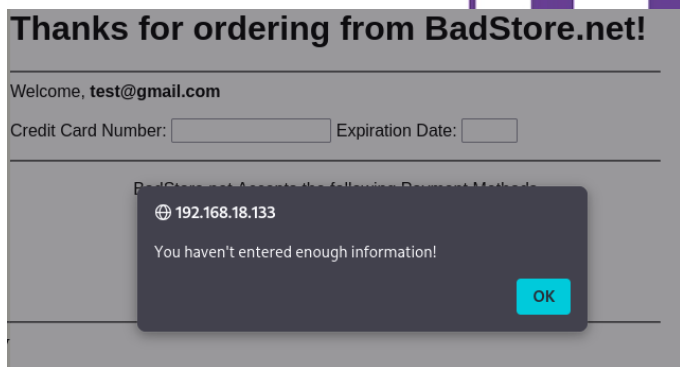


Figure 35

I tested cryptography controls by testing the HTTPS configuration, the web application allows HTTP connections there is no enforcement of HTTPS as seen in figure 26 the browser clearly states not secure also with a http connection.

As per figure 25 (step 6 cookie security) once user has logged in or registered an account a session cookie is created but this doesn't enforce https either and is marked as false for the secure field when viewing the cookie in DEV tools. It seems the web application has weak cryptography controls, which could allow attackers to intercept sensitive data and therefore could perform man in the middle attacks or session hijacking.

6.10 BUSINESS LOGIC TESTING (WSTG-BUSL)



I attempted to bypass the workflow of the web application by trying to place an order without entering any details this was not possible on this occasion the web application did have necessary field validation, I received an error message as seen in figure.

As shown in figure 20 (Step 3 Lack of validation) there is the possibility within the web application to repeat certain actions and there be no validation or error message preventing you from doing so. In this case whilst being logged into a test account I can create another account with the exact same name email address.

6.11 CLIENT-SIDE TESTING (WSTG-CLNT)

DO NOT COPY

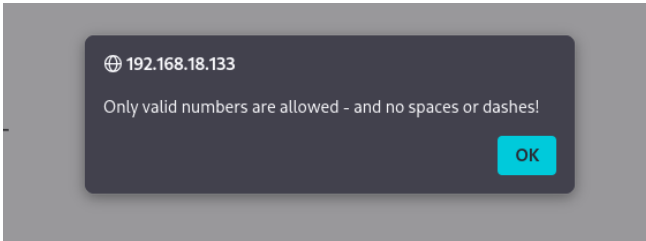


Figure 36-Placing order with incorrect input Before JavaScript was Disabled

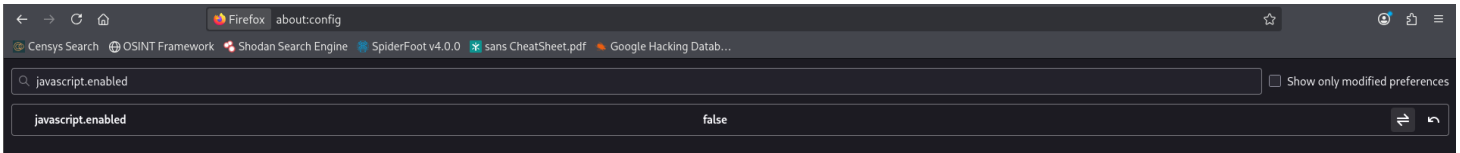


Figure 37- Disabling JavaScript

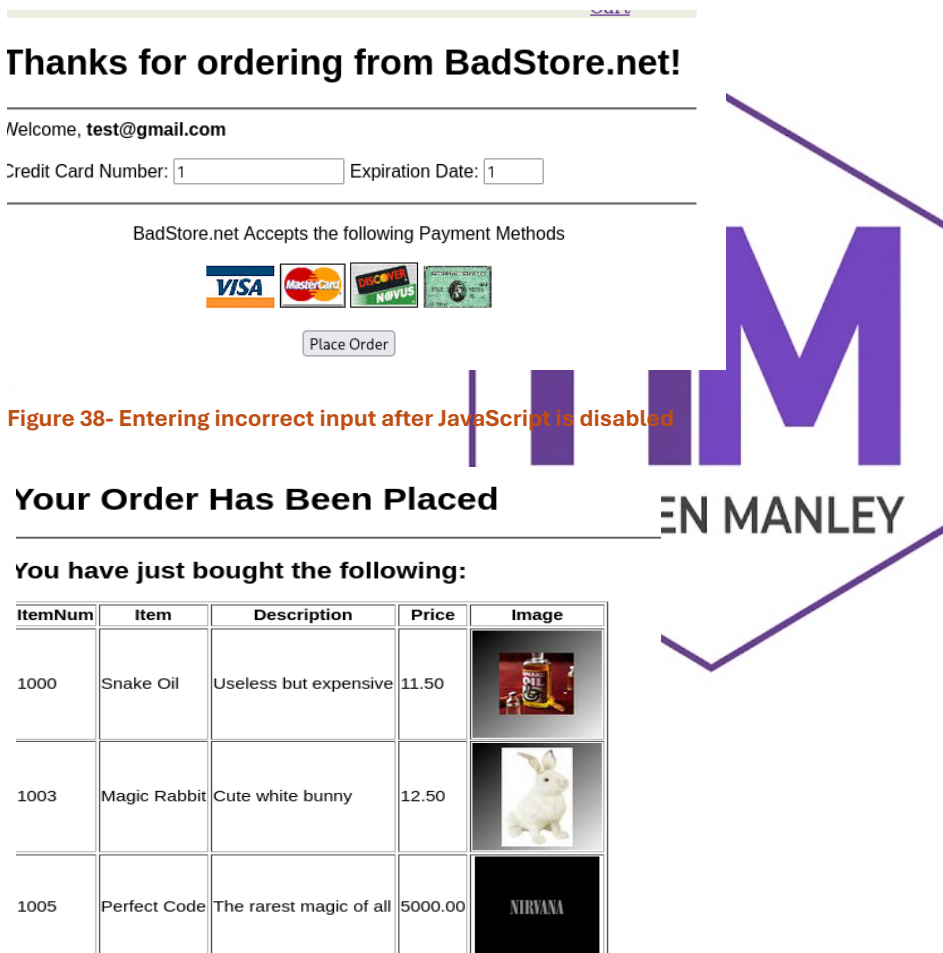


Figure 38- Entering incorrect input after JavaScript is disabled

As seen in figure 31 JavaScript was disabled in the browser using Firefox configuration, I did this to assess if client-side controls could be bypassed. Once I disabled JavaScript the application failed to enforce input validation allowing actions to still occur without necessary checks for example payment input for placing an order.

6.12 API TESTING (WSTGAP)

DO NOT COPY

Not Found

The requested URL /badstore.cgi was not found on this server.

Apache/1.3.28 Server at 192.168.18.133 Port 80

I conducted API endpoint testing by attempting to directly access backend resources such as /badstore.cgi and modifying parameters such as ?id=1, all my attempts returned a not found response seen in figure X this indicates that the endpoints are not publicly accessible. However as seen above it is very clear and very publicly accessible the version of the site Apache 1.3.28.

No additional API-related vulnerabilities were identified through forced browsing.

7.0 Social Engineering Phishing Email

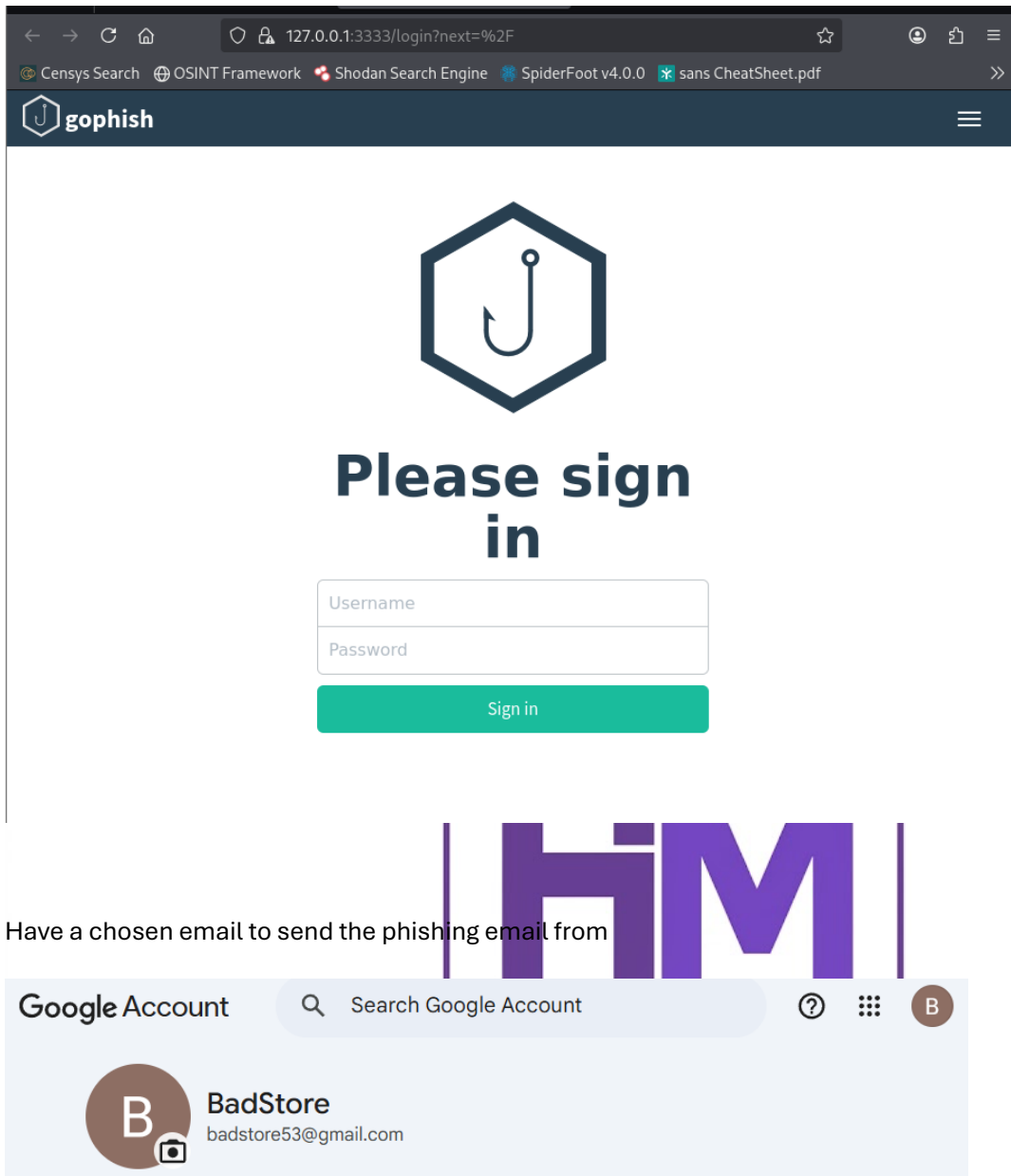
Run go fish

```
$ gophish
Starting gophish ...
Default user is: admin
Default password is: kali-gophish
Opening Web UI https://127.0.0.1:3333
(kali@kali)-[~]
$
```

Gofish login page



DO NOT COPY



Create an App password trough email account

DO NOT COPY

← App passwords

App passwords help you sign into your Google Account on older apps and services that don't support modern security standards.

App passwords are less secure than using up-to-date apps and services that use modern security standards. Before you create an app password, you should check to see if your app needs this in order to sign in.

[Learn more](#)

You don't have any app passwords.

To create a new app specific password, type a name for it below...

App name

Create

Generated app password

Your app password for your device

xivv vexr eypu tepb

How to use it

Go to the settings for your Google Account in the application or device you are trying to set up. Replace your password with the 16-character password shown above.

Just like your normal password, this app password grants complete access to your Google Account. You won't need to remember it, so don't write it down or share it with anyone.

DO NOT COPY

Setup sending profile

New Sending Profile ×

Name:

BadStore IT Department

Interface Type:

SMTP

SMTP From: ⓘ

badstore53@gmail.com

Host:

smtpgmail.com:587

Username:

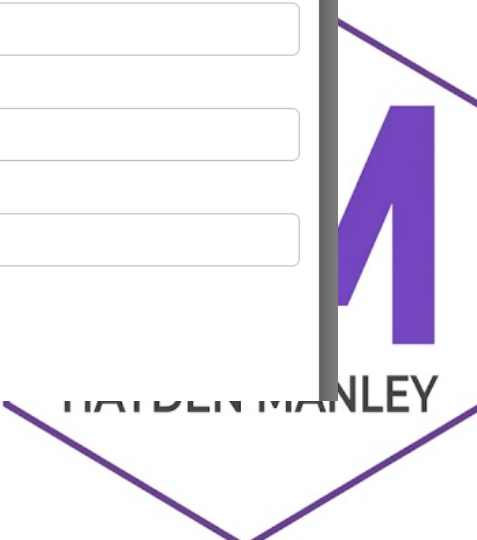
badstore53@gmail.com

Password:

.....

☒ Ignore Certificate Errors ⓘ

Email Headers:



DO NOT COPY

Copy site source to be cloned, in this case supplier login page

```
view-source:http://192.168.211.134/cgi-bin/badstore.cgi?action=
Censys Search OSINT Framework Shodan Search Engine SpiderFoot v4.0.0 sans CheatSheet.pdf

1 <BODY bgColor=#ffffff leftMargin=0 topMargin=0 MARGINHEIGHT="0" MARGINWIDTH="0">
2
3 <TABLE cellSpacing=0 cellPadding=0 width=760 bgColor=#004b2c border=0>
4 <TBODY>
5 <TR>
6 <TD width=326 bgColor=#004b2c>
7 <IMG height=60 alt="BadStore.net" hspace=0 src="/images/BadStore.jpg"
8 width=350
9 border=0>
10 </TD></TR></TBODY></TABLE>
11 <TABLE cellSpacing=0 cellPadding=0 width=760 border=0>
12 <TBODY>
13 <TR vAlign=top align=left>
14 <TD vAlign=top width=143 bgColor=#e0e0e0>
15 <TABLE cellSpacing=0 cellPadding=0 width=143 bgColor=#004b2c border=0>
16 <FORM name=search onSubmit=/cgi-bin/badstore.cgi
17 method=get>
18 <TBODY>
19 <TR>
20 <TD vAlign=top width=143 colSpan=3>
21 <TABLE cellSpacing=0 cellPadding=0 width=143 border=0>
22 <TBODY>
23 <TR bgColor=#004b2c>
24 </TR>
25 <TR vAlign=center bgColor=#004b2c width="138">
26 <TD class=normal width=94 height=30>&nbsp;&nbsp;&nbsp;<INPUT class=normal
27 maxLength=60 size=10 name=searchquery> </TD>
28 <font color=yellow size=2 face=Arial><Center><B>Quick Item Search</B></Center></font>
29 <TD width=44>
30 <BR><INPUT type=hidden value='search' name='action'>
31 <INPUT
32 onClick="Go Search" type=image height=25 alt="Go Search"
33 width=44
34 src="/images/index.gif"
35 border=0></A></TD></TR>
36 <TR bgColor=#004b2c>
37 </TR>
38 <TR>
39 <TD colSpan=2></TD></TR></TBODY></FORM></TABLE></TD></TR>
40 <TR bgColor=#e0e0e0>
41
42 <TD class=normal width=135><BR>
43 <A HREF="/cgi-bin/badstore.cgi">Home </A><BR>
44 <P>
45 <A HREF="/cgi-bin/badstore.cgi?action=whatsnew">What's New </A><BR>
46 <P>
47 <A HREF="/cgi-bin/badstore.cgi?action=guestbook">Sign Our Guestbook </A><BR>
48
```

HAYDEN MANLEY

Copy into landing page on go fish

DO NOT COPY

The screenshot shows the Burp Suite interface. On the left is a sidebar with navigation options: Dashboard, Campaigns, Users & Groups, Email Templates, Landing Pages, Sending Profiles, Account Settings, User Management, Webhooks, and User Guide. The main area displays the 'BadStore Login Page' with a red 'Import Site' button. Below this, the 'HTML' tab is active, showing the source code of the page. The code is an HTML form for logging in to 'BadStore v1.2.3s'. It includes fields for 'Email Address' and 'Password', and a 'Login' submit button. The form uses POST method and is encoded in application/x-www-form-urlencoded. The page title is 'BadStore Login Page'.

Name:

BadStore Login Page

Import Site

HTML

Source

```
<?HEAD><BODY><H1>welcome Supplier - Please Login.</H1><FORM
METHOD="POST" ACTION="/cgi-bin/badstore.cgi?action=supplierportal"
ENCTYPE="application/x-www-form-urlencoded">
  Email Address: <INPUT TYPE="text" NAME="email" SIZE=15
MAXLENGTH=40><P> Password: <INPUT TYPE="password" NAME="passwd" SIZE=8
8><P><INPUT TYPE="submit" NAME="Login" VALUE="Login"></
FORM><HR><P><BR><Center><FONT SIZE=2, FACE='Times'>BadStore v1.2.3s -
Copyright &#169; 2004-2005</Center>
</BODY></HTML>
```

☐ Capture Submitted Data ?

Create email template enter text or HTML and add nay images as seen blow I have added the BadStore logo

Edit Template

Name:

BadStore Login

+ Import Email

Envelope Sender: ⓘ

badstore53@gmail.com

Subject:

CREDENTIALS COMPROMISED RESET PASSWORD

TextHTML

Dear Supplier

We have noticed your login credentials have been compromised please you the link below to change your password as soon as possible.

Sent from my iPhone

IT Department

☐ Add Tracking Image

+ Add Files

Show entriesSearch:

Name

unnamed.png

Showing 1 to 1 of 1 entriesPrevious1Next

DO NOT COPY

Add user group this is the address of the victims

Name:

Supplier

+ Bulk Import Users

Download CSV Template

BadStore

Last Nam

badstore53@gmail

Position

+ Add

Show

10

entries

Search:

First Name

Last Name

Email

Position

No data available in table

Showing 0 to 0 of 0 entries

Previous

Next



Launch a campaign

New Campaign

Name:

Bad Store IT Department

Email Template:

BadStore Login

Landing Page:

BadStore Login Page

URL:

192.168.211.133

Launch Date

April 6th 2026, 3:24 am

Send Emails By (Optional)

Sending Profile:

BadStore IT Department

Send Test Email

Groups:

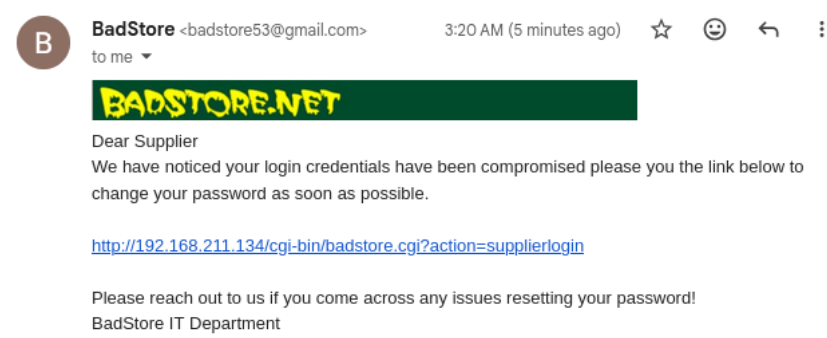
x Supplier

Close

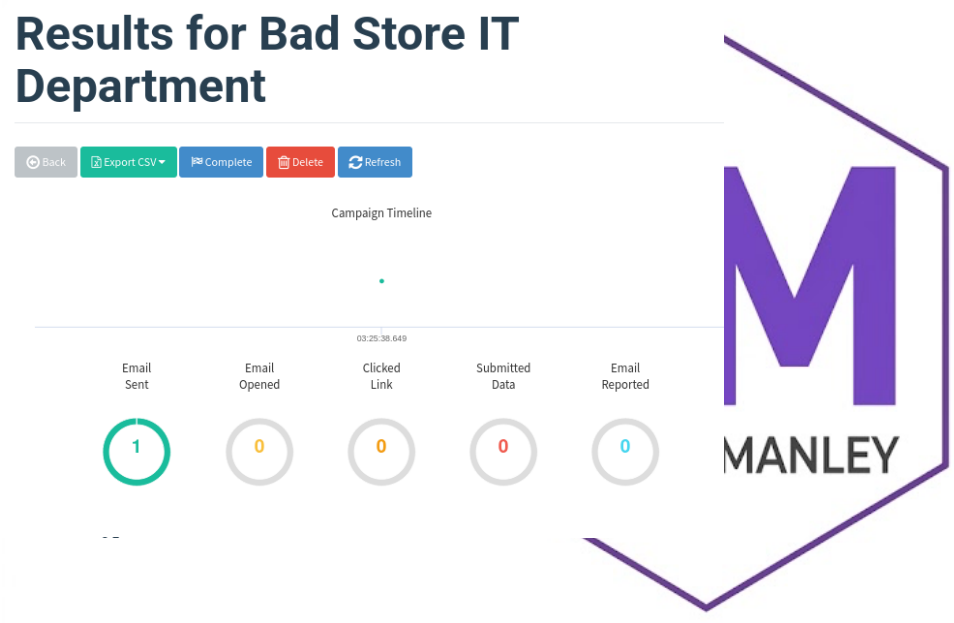
Launch Campaign

DO NOT COPY

Email is sent



Back on the go fish portal we can track the campaign and wait to tap into any login credential that are entered by the victim



7.1 References

<https://www.browserstack.com/guide/penetration-testing-report-guide>

<https://www.hackthebox.com/blog/penetration-testing-reports-template-and-guide>

[2025 Ransomware Trends: From Risk to Resilience](#)

[CVE security vulnerability database. Security vulnerabilities, exploits, references and more\]](#)

7.2 Appendix

Tools Table

Category	Tool	Description
----------	------	-------------

DO NOT COPY

Host Discovery	Net Discover	Used to identify devices on the local network and find the target IP address.
Web Scanner	WhatWeb	Used to fingerprint target web application and identify technologies such as the server frameworks and scripting language.
Network scanner	NMAP	Used for host discovery , port scanning, service and version detection and a broader enumeration of the target system.
Content Discovery	Gobuster	Used to discover hidden directories and endpoints such as /admin, /login and /backup.
Web Proxy	BurpSuite	Used to intercept and inspect HTTP traffic and builds a site map of the applications pages and endpoints.
Vulnerability Scanner	Nikto	Used to detect web server misconfigurations .
Web scanner	OWASP ZAP Spider	Used to crawl the application and identify accessible URLs directories and parameters.
Web Scanner	OWASP ZAP AJAX Spider	Used to execute JavaScript while crawling so dynamic content and hidden application paths can be found.



Full NMAP Vulners Scan

DO NOT COPY

```
(kali@kali)-[~]
$ nmap -p- -sV --script vulners 192.168.211.134
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-05 08:34 -0400
Nmap scan report for 192.168.211.134
Host is up (0.0021s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http    Apache httpd 1.3.28 ((Unix) mod_ssl/2.8.15 OpenSSL/0.9.7c)
|_ http-server-header: Apache/1.3.28 (Unix) mod_ssl/2.8.15 OpenSSL/0.9.7c
|_ vulners:
|_ cpe:/a:apache:http_server:1.3.28:
|_ HTTPD:186F8E9AD2C9495C370F3BFAD6F3CC4 10.0 h
https://vulners.com/httpd/HTTPD:186F8E9AD2C9495C370F3BFAD6F3CC4
|_ CVE-2004-0492 10.0 https://vulners.com/cve/CVE-2004-0492
|_ 3E6BA608-776F-5B1F-9BA5-589CD2A5A351 10.0 h
https://vulners.com/gitee/3E6BA608-776F-5B1F-9BA5-589CD2A5A351 *EXPLOIT*
|_ HTTPD:B060BFAA862DD69F70DB2412EAE10DE9 7.8 h
https://vulners.com/httpd/HTTPD:B060BFAA862DD69F70DB2412EAE10DE9
|_ CVE-2004-0940 7.8 https://vulners.com/cve/CVE-2004-0940
|_ SSV:6610 7.6 https://vulners.com/seebug/SSV:6610 *EXPLOIT*
|_ SSV:63874 7.6 https://vulners.com/seebug/SSV:63874 *EXPLOIT*
|_ SSV:429 7.6 https://vulners.com/seebug/SSV:429 *EXPLOIT*
|_ SSV:16391 7.6 https://vulners.com/seebug/SSV:16391 *EXPLOIT*
|_ SAINT:B572402CE6E5C851D7572BF044507A14 7.6 h
https://vulners.com/saint/SAINT:B572402CE6E5C851D7572BF044507A14 *EXPLOIT*
|_ SAINT:386ECCECD3AA34FA1E84E6D3D2B71C7B 7.6 h
https://vulners.com/saint/SAINT:386ECCECD3AA34FA1E84E6D3D2B71C7B *EXPLOIT*
|_ SAINT:35A5AA91DCF68555669689272BFFD3E7 7.6 h
https://vulners.com/saint/SAINT:35A5AA91DCF68555669689272BFFD3E7 *EXPLOIT*
|_ SAINT:14705540EFEE2160EBFBAF5BDA3E828C 7.6 h
https://vulners.com/saint/SAINT:14705540EFEE2160EBFBAF5BDA3E828C *EXPLOIT*
|_ PACKETSTORM:83108 7.6 https://vulners.com/packetstorm/PACKETSTORM:83108 *EXPLOIT*
|_ CVE-2003-0542 7.2 https://vulners.com/cve/CVE-2003-0542
|_ SSV:19019 6.8 https://vulners.com/seebug/SSV:19019 *EXPLOIT*
|_ HTTPD:C7445200CAFE5527BA15F7BB8AF90D9F 6.8 h
https://vulners.com/httpd/HTTPD:C7445200CAFE5527BA15F7BB8AF90D9F
|_ CVE-2010-0010 6.8 https://vulners.com/cve/CVE-2010-0010
|_ SSV:66957 5.0 https://vulners.com/seebug/SSV:66957 *EXPLOIT*
|_ SSV:20993 5.0 https://vulners.com/seebug/SSV:20993 *EXPLOIT*
|_ SSV:20979 5.0 https://vulners.com/seebug/SSV:20979 *EXPLOIT*
|_ SSV:20969 5.0 https://vulners.com/seebug/SSV:20969 *EXPLOIT*
|_ SSV:17994 5.0 https://vulners.com/seebug/SSV:17994 *EXPLOIT*
|_ SSV:14432 5.0 https://vulners.com/seebug/SSV:14432 *EXPLOIT*
|_ PACKETSTORM:85018 5.0 https://vulners.com/packetstorm/PACKETSTORM:85018 *EXPLOIT*
|_ PACKETSTORM:82197 5.0 https://vulners.com/packetstorm/PACKETSTORM:82197 *EXPLOIT*
|_ PACKETSTORM:181059 5.0 https://vulners.com/packetstorm/PACKETSTORM:181059 *EXPLOIT*
|_ PACKETSTORM:105672 5.0 https://vulners.com/packetstorm/PACKETSTORM:105672 *EXPLOIT*
|_ PACKETSTORM:105591 5.0 https://vulners.com/packetstorm/PACKETSTORM:105591 *EXPLOIT*
|_ MSF:AUXILIARY-SCANNER-HTTP-REWRITE_PROXY_BYPASS 5.0 https://vulners.com/metasploit/MSF:AUXILIARY-SCANNER-HTTP-REWRITE_PROXY_BYPASS *EXPLOIT*
|_ HTTPD:7B789993A3BDA0E4D014A8671E97D1EA 5.0 h
https://vulners.com/httpd/HTTPD:7B789993A3BDA0E4D014A8671E97D1EA
|_ HTTPD:251E9EE30116844024950699040C983B 5.0 h
https://vulners.com/httpd/HTTPD:251E9EE30116844024950699040C983B
|_ EXPLOITPACK:460143F0ACAE117DD79BD75EDFDA154B 5.0 https://vulners.com/exploitpack/EXPLOITPACK:460143F0ACAE117DD79BD75EDFDA154B *EXPLOIT*
|_ EXPLOITPACK:44DAC602FB30402C58970DFAB1C4AF87 5.0 https://vulners.com/exploitpack/EXPLOITPACK:44DAC602FB30402C58970DFAB1C4AF87 *EXPLOIT*
|_ EDB-ID:9887 5.0 https://vulners.com/exploit/EDB-ID:9887 *EXPLOIT*
```



DO NOT COPY

```
loitdb/EDB-ID:9887 *EXPLOIT*
| EDB-ID:17969 5.0 https://vulners.com/exp
loitdb/EDB-ID:17369 *EXPLOIT*
| CVE-2011-3368 5.0 https://vulners.com/cve
/CVE-2011-3368
| CVE-2007-6750 5.0 https://vulners.com/cve
/CVE-2007-6750
| CVE-2004-0263 5.0 https://vulners.com/cve
/CVE-2004-0263
| CVE-2003-0020 5.0 https://vulners.com/cve
/CVE-2003-0020
| CVE-2001-1556 5.0 https://vulners.com/cve
/CVE-2001-1556
| SSV:2174 4.7 https://vulners.com/see
bug/SSV:2174 *EXPLOIT*
| HTTPD:B63CF0157386C00B8FF9E943DA8F9A2F 4.7 h
https://vulners.com/httpd/HTTPD:B63CF0157386C00B8FF9E943
DA8F9A2F
| CVE-2007-3304 4.7 https://vulners.com/cve
/CVE-2007-3304
| SSV:71772 4.3 https://vulners.com/see
bug/SSV:71772 *EXPLOIT*
| SSV:2818 4.3 https://vulners.com/see
bug/SSV:2818 *EXPLOIT*
| SSV:2801 4.3 https://vulners.com/see
bug/SSV:2801 *EXPLOIT*
| SSV:24250 4.3 https://vulners.com/see
bug/SSV:24250 *EXPLOIT*
| PACKETSTORM:61420 4.3 https://vulners
.com/packetstorm/PACKETSTORM:61420 *EXPLOIT*
| PACKETSTORM:102234 4.3 https://vulners
.com/packetstorm/PACKETSTORM:102234 *EXPLOIT*
| HTTPD:BE276450B6181A981775FFC94F438B18 4.3 h
https://vulners.com/httpd/HTTPD:BE276450B6181A981775FFC9
4F438B18
| HTTPD:99DE1CD158F65B4CFEA650CE55560C45 4.3 h
https://vulners.com/httpd/HTTPD:99DE1CD158F65B4CFEA650CE
55560C45
| HTTPD:5BBBCCFAA0C8B536B2CC3DA9DE0736F0 4.3 h
https://vulners.com/httpd/HTTPD:5BBBCCFAA0C8B536B2CC3DA9
DE0736F0
| HTTPD:4552C39F6C7671DAFFFFFFF7180F10B92D 4.3 h
https://vulners.com/httpd/HTTPD:4552C39F6C7671DAFFFFFFF718
0F10B92D
| HTTPD:44908D5C4721DCB28E9FB7C9E680D98A 4.3 h
https://vulners.com/httpd/HTTPD:44908D5C4721DCB28E9FB7C9
E680D98A
| EXPLOITPACK:683C3B1D02827D6B32706DB1D146B2D8 4
```

HM
HAYDEN MANLEY

DO NOT COPY

```
.com/packetstorm/PACKETSTORM:83108 *EXPLOIT*
| PACKETSTORM:62377 7.6 https://vulners
.com/packetstorm/PACKETSTORM:62377 *EXPLOIT*
| PACKETSTORM:56989 7.6 https://vulners
.com/packetstorm/PACKETSTORM:56989 *EXPLOIT*
| PACKETSTORM:55727 7.6 https://vulners
.com/packetstorm/PACKETSTORM:55727 *EXPLOIT*
| PACKETSTORM:49400 7.6 https://vulners
.com/packetstorm/PACKETSTORM:49400 *EXPLOIT*
| MSF:EXPLOIT-WINDOWS-HTTP-APACHE_MOD_REWRITE_LDA
p- 7.6 https://vulners.com/metasploit/MSF:EXPL
OIT-WINDOWS-HTTP-APACHE_MOD_REWRITE_LDAP- *EXPLOI
T*
| HTTPD:8D0D2AA3CE8F589BE9399D00A97A82F7 7.6 h
https://vulners.com/httpd/HTTPD:8D0D2AA3CE8F589BE9399D00
A97A82F7
| EXPLOITPACK:8FEBCD1B617ED74B8D2179061252A44 7
.6 https://vulners.com/exploitpack/EXPLOITPACK:8FE
BCD1B617ED74B8D2179061252A44 *EXPLOIT*
| EXPLOITPACK:6E3090CD46CEEE08D52992589E824D90 7
.6 https://vulners.com/exploitpack/EXPLOITPACK:6E3
090CD46CEEE08D52992589E824D90 *EXPLOIT*
| EDB-ID:3680 7.6 https://vulners.com/exp
loitdb/EDB-ID:3680 *EXPLOIT*
| EDB-ID:2237 7.6 https://vulners.com/exp
loitdb/EDB-ID:2237 *EXPLOIT*
| EDB-ID:16752 7.6 https://vulners.com/exp
loitdb/EDB-ID:16752 *EXPLOIT*
| CVE-2006-3747 7.6 https://vulners.com/cve
/CVE-2006-3747
| HTTPD:EA65344DAE2D5CDBD3227D99A03949E9 7.5 h
https://vulners.com/httpd/HTTPD:EA65344DAE2D5CDBD3227D99
A03949E9
| HTTPD:67FAF457E140172987C21E55FCF24788 7.5 h
https://vulners.com/httpd/HTTPD:67FAF457E140172987C21E55
FCF24788
| HTTPD:0576286DB2485FBB76346020044ABE4A 7.5 h
https://vulners.com/httpd/HTTPD:0576286DB2485FBB76346020
044ABE4A
| CVE-2004-1082 7.5 https://vulners.com/cve
/CVE-2004-1082
| CVE-2003-0993 7.5 https://vulners.com/cve
/CVE-2003-0993
| CVE-2003-0987 7.5 https://vulners.com/cve
/CVE-2003-0987
| HTTPD:18EAF7F92541BF62857123A840724D27 7.2 h
https://vulners.com/httpd/HTTPD:18EAF7F92541BF62857123A8
40724D27
```



DO NOT COPY

```
https://vulners.com/httpd/HTTPD:18EAF7F92541BF62857123A8
40724D27
| CVE-2003-0542 7.2 https://vulners.com/cve
/CVE-2003-0542
| SSV:19019 6.8 https://vulners.com/see
bug/SSV:19019 *EXPLOIT*
| HTTPD:C7445200CAFE5527BA15F7B88AF90D9F 6.8 h
https://vulners.com/httpd/HTTPD:C7445200CAFE5527BA15F7B8
8AF90D9F
| CVE-2010-0010 6.8 https://vulners.com/cve
/CVE-2010-0010
| SSV:66957 5.0 https://vulners.com/see
bug/SSV:66957 *EXPLOIT*
| SSV:20993 5.0 https://vulners.com/see
bug/SSV:20993 *EXPLOIT*
| SSV:20979 5.0 https://vulners.com/see
bug/SSV:20979 *EXPLOIT*
| SSV:20969 5.0 https://vulners.com/see
bug/SSV:20969 *EXPLOIT*
| SSV:17994 5.0 https://vulners.com/see
bug/SSV:17994 *EXPLOIT*
| SSV:14432 5.0 https://vulners.com/see
bug/SSV:14432 *EXPLOIT*
| PACKETSTORM:85018 5.0 https://vulners
.com/packetstorm/PACKETSTORM:85018 *EXPLOIT*
| PACKETSTORM:82197 5.0 https://vulners
.com/packetstorm/PACKETSTORM:82197 *EXPLOIT*
| PACKETSTORM:181059 5.0 https://vulners
.com/packetstorm/PACKETSTORM:181059 *EXPLOIT*
| PACKETSTORM:105672 5.0 https://vulners
.com/packetstorm/PACKETSTORM:105672 *EXPLOIT*
| PACKETSTORM:105591 5.0 https://vulners
.com/packetstorm/PACKETSTORM:105591 *EXPLOIT*
| MSF:AUXILIARY-SCANNER-HTTP-REWRITE_PROXY_BYPASS
- 5.0 https://vulners.com/metasploit/MSF:AUXI
LIARY-SCANNER-HTTP-REWRITE_PROXY_BYPASS-
*EXPLOIT*
| HTTPD:7B789993A3BDA0E4D014A8671E97D1EA 5.0 h
https://vulners.com/httpd/HTTPD:7B789993A3BDA0E4D014A867
1E97D1EA
| HTTPD:251E9EE30116844024950699040C983B 5.0 h
https://vulners.com/httpd/HTTPD:251E9EE30116844024950699
040C983B
| EXPLOITPACK:460143F0ACAE117DD79BD75EDFDA154B 5
.0 https://vulners.com/exploitpack/EXPLOITPACK:460
143F0ACAE117DD79BD75EDFDA154B *EXPLOIT*
| EXPLOITPACK:44DAC602FB30402C58970DFAB1C4AF87 5
.0 https://vulners.com/exploitpack/EXPLOITPACK:44D
AC602FB30402C58970DFAB1C4AF87 *EXPLOIT*
| EDB-ID:9887 5.0 https://vulners.com/exp
loitdb/EDB-ID:9887 *EXPLOIT*
| EDB-ID:17969 5.0 https://vulners.com/exp
loitdb/EDB-ID:17969 *EXPLOIT*
| CVE-2011-3368 5.0 https://vulners.com/cve
/CVE-2011-3368
| CVE-2007-6750 5.0 https://vulners.com/cve
/CVE-2007-6750
| CVE-2004-0263 5.0 https://vulners.com/cve
/CVE-2004-0263
| CVE-2003-0020 5.0 https://vulners.com/cve
/CVE-2003-0020
| CVE-2001-1556 5.0 https://vulners.com/cve
/CVE-2001-1556
| SSV:2174 4.7 https://vulners.com/see
bug/SSV:2174 *EXPLOIT*
| HTTPD:B63CF0157386C00B8FF9E943DA8F9A2F 4.7 h
https://vulners.com/httpd/HTTPD:B63CF0157386C00B8FF9E943
DA8F9A2F
| CVE-2007-3304 4.7 https://vulners.com/cve
/CVE-2007-3304
| SSV:71772 4.3 https://vulners.com/see
bug/SSV:71772 *EXPLOIT*
| SSV:2818 4.3 https://vulners.com/see
bug/SSV:2818 *EXPLOIT*
| SSV:2801 4.3 https://vulners.com/see
bug/SSV:2801 *EXPLOIT*
| SSV:24250 4.3 https://vulners.com/see
bug/SSV:24250 *EXPLOIT*
| PACKETSTORM:61420 4.3 https://vulners
.com/packetstorm/PACKETSTORM:61420 *EXPLOIT*
| PACKETSTORM:102234 4.3 https://vulners
.com/packetstorm/PACKETSTORM:102234 *EXPLOIT*
| HTTPD:BE276450B6181A981775FFC94F438B18 4.3 h
https://vulners.com/httpd/HTTPD:BE276450B6181A981775FFC9
4F438B18
| HTTPD:99DE1CD158F65B4CFEA650CE55560C45 4.3 h
https://vulners.com/httpd/HTTPD:99DE1CD158F65B4CFEA650CE
55560C45
| HTTPD:5BBBCCFAA0C8B536B2CC3DA9DE0736F0 4.3 h
https://vulners.com/httpd/HTTPD:5BBBCCFAA0C8B536B2CC3DA9
DE0736F0
| HTTPD:4552C39F6C7671DAFFFFF7180F10B92D 4.3 h
https://vulners.com/httpd/HTTPD:4552C39F6C7671DAFFFFF718
0F10B92D
| HTTPD:44908D5C4721DCB28E9FB7C9E680D98A 4.3 h
https://vulners.com/httpd/HTTPD:44908D5C4721DCB28E9FB7C9
```



DO NOT COPY

```
E680D98A
| EXPLOITPACK:683C3B1D02827D6B32706DB1D146B2D8 4
|.3 https://vulners.com/exploitpack/EXPLOITPACK:683
C3B1D02827D6B32706DB1D146B2D8 *EXPLOIT*
| EDB-ID:17393 4.3 https://vulners.com/exp
loitdb/EDB-ID:17393 *EXPLOIT*
| CVE-2011-4317 4.3 https://vulners.com/cve
/CVE-2011-4317
| CVE-2007-6388 4.3 https://vulners.com/cve
/CVE-2007-6388
| CVE-2007-5000 4.3 https://vulners.com/cve
/CVE-2007-5000
| CVE-2006-5752 4.3 https://vulners.com/cve
/CVE-2006-5752
| CVE-2006-3918 4.3 https://vulners.com/cve
/CVE-2006-3918
| CVE-2005-3352 4.3 https://vulners.com/cve
/CVE-2005-3352
| 1337DAY-ID-9952 0.0 https://vulners.com/zdt
/1337DAY-ID-9952 *EXPLOIT*
| 1337DAY-ID-6193 0.0 https://vulners.com/zdt
/1337DAY-ID-6193 *EXPLOIT*
| 1337DAY-ID-16843 0.0 https://vulners
.com/zdt/1337DAY-ID-16843 *EXPLOIT*
| 1337DAY-ID-16323 0.0 https://vulners
.com/zdt/1337DAY-ID-16323 *EXPLOIT*
443/tcp open ssl/http Apache httpd 1.3.28 ((Unix) mod
_ssl/2.8.15 OpenSSL/0.9.7c)
|_http-server-header: Apache/1.3.28 (Unix) mod_ssl/2.8.
15 OpenSSL/0.9.7c
| vulners:
| cpe:/a:apache:http_server:1.3.28:
| HTTPD:186F8E9AD2C9495C370F3BFAD6F3CC4 10.0 h
tps://vulners.com/httpd/HTTPD:186F8E9AD2C9495C370F3BFA
DE6F3CC4
| CVE-2004-0492 10.0 https://vulners.com/cve
/CVE-2004-0492
| 3E6BA608-776F-5B1F-9BA5-589CD2A5A351 10.0 h
tps://vulners.com/gitee/3E6BA608-776F-5B1F-9BA5-589CD2
A5A351 *EXPLOIT*
| HTTPD:B060BFAA862DD69F70DB2412EAE10DE9 7.8 h
tps://vulners.com/httpd/HTTPD:B060BFAA862DD69F70DB2412
EAE10DE9
| CVE-2004-0940 7.8 https://vulners.com/cve
/CVE-2004-0940
| SSV:6610 7.6 https://vulners.com/see
bug/SSV:6610 *EXPLOIT*
```

HM
DEN MANLEY

DO NOT COPY

```
| SSV:63874 7.6 https://vulners.com/see
bug/SSV:63874 *EXPLOIT*
| SSV:429 7.6 https://vulners.com/seebug/SSV:
429 *EXPLOIT*
| SSV:16391 7.6 https://vulners.com/see
bug/SSV:16391 *EXPLOIT*
| SAINT:B572402CE6E5C851D7572BF044507A14 7.6 h
ttps://vulners.com/saint/SAINT:B572402CE6E5C851D7572BF0
44507A14 *EXPLOIT*
| SAINT:386ECCECD3AA34FA1E84E6D3D2B71C7B 7.6 h
ttps://vulners.com/saint/SAINT:386ECCECD3AA34FA1E84E6D3
D2B71C7B *EXPLOIT*
| SAINT:35A5AA91DCF68555669689272BFDD3E7 7.6 h
ttps://vulners.com/saint/SAINT:35A5AA91DCF6855566968927
2BFDD3E7 *EXPLOIT*
| SAINT:14705540EFEE2160EBFBAF5BDA3E828C 7.6 h
ttps://vulners.com/saint/SAINT:14705540EFEE2160EBFBAF5B
DA3E828C *EXPLOIT*
| PACKETSTORM:83108 7.6 https://vulners
.com/packetstorm/PACKETSTORM:83108 *EXPLOIT*
| PACKETSTORM:62377 7.6 https://vulners
.com/packetstorm/PACKETSTORM:62377 *EXPLOIT*
| PACKETSTORM:56989 7.6 https://vulners
.com/packetstorm/PACKETSTORM:56989 *EXPLOIT*
| PACKETSTORM:55727 7.6 https://vulners
.com/packetstorm/PACKETSTORM:55727 *EXPLOIT*
| PACKETSTORM:49400 7.6 https://vulners
.com/packetstorm/PACKETSTORM:49400 *EXPLOIT*
| MSF:EXPLOIT-WINDOWS-HTTP-APACHE_MOD_REWRITE_LDAP-
P- 7.6 https://vulners.com/metasploit/MSF:EXPL
OIT-WINDOWS-HTTP-APACHE_MOD_REWRITE_LDAP-
T* *EXPLOIT*
| HTTPD:8D0D2AA3CE8F589BE9399D00A97A82F7 7.6 h
ttps://vulners.com/httpd/HTTPD:8D0D2AA3CE8F589BE9399D00
A97A82F7
| EXPLOITPACK:8FEBCD1B617ED74B8D2179061252A44 7
.6 https://vulners.com/exploitpack/EXPLOITPACK:8FE
BCD1B617ED74B8D2179061252A44 *EXPLOIT*
| EXPLOITPACK:6E3090CD46CEEE08D52992589E824D90 7
.6 https://vulners.com/exploitpack/EXPLOITPACK:6E3
090CD46CEEE08D52992589E824D90 *EXPLOIT*
| EDB-ID:3680 7.6 https://vulners.com/exp
loitdb/EDB-ID:3680 *EXPLOIT*
| EDB-ID:2237 7.6 https://vulners.com/exp
loitdb/EDB-ID:2237 *EXPLOIT*
```



DO NOT COPY

```
| EDB-ID:16752 7.6 https://vulners.com/exp
loitdb/EDB-ID:16752 *EXPLOIT*
| CVE-2006-3747 7.6 https://vulners.com/cve
/CVE-2006-3747
| HTTPD:EA65344DAE2D5CDBD3227D99A03949E9 7.5 h
https://vulners.com/httpd/HTTPD:EA65344DAE2D5CDBD3227D99
A03949E9
| HTTPD:67FAF457E140172987C21E55FCF24788 7.5 h
https://vulners.com/httpd/HTTPD:67FAF457E140172987C21E55
FCF24788
| HTTPD:0576286DB2485FBB76346020044ABE4A 7.5 h
https://vulners.com/httpd/HTTPD:0576286DB2485FBB76346020
044ABE4A
| CVE-2004-1082 7.5 https://vulners.com/cve
/CVE-2004-1082
| CVE-2003-0993 7.5 https://vulners.com/cve
/CVE-2003-0993
| CVE-2003-0987 7.5 https://vulners.com/cve
/CVE-2003-0987
| HTTPD:18EAF7F92541BF62857123A840724D27 7.2 h
https://vulners.com/httpd/HTTPD:18EAF7F92541BF62857123A8
40724D27
| CVE-2003-0542 7.2 https://vulners.com/cve
/CVE-2003-0542
| SSV:19019 6.8 https://vulners.com/see
bug/SSV:19019 *EXPLOIT*
| HTTPD:C7445200CAFE5527BA15F7BB8AF90D9F 6.8 h
https://vulners.com/httpd/HTTPD:C7445200CAFE5527BA15F7BB
8AF90D9F
| CVE-2010-0010 6.8 https://vulners.com/cve
/CVE-2010-0010
| SSV:66957 5.0 https://vulners.com/see
bug/SSV:66957 *EXPLOIT*
| SSV:20993 5.0 https://vulners.com/see
bug/SSV:20993 *EXPLOIT*
| SSV:20979 5.0 https://vulners.com/see
bug/SSV:20979 *EXPLOIT*
| SSV:20969 5.0 https://vulners.com/see
bug/SSV:20969 *EXPLOIT*
| SSV:17994 5.0 https://vulners.com/see
bug/SSV:17994 *EXPLOIT*
| SSV:14432 5.0 https://vulners.com/see
bug/SSV:14432 *EXPLOIT*
| PACKETSTORM:85018 5.0 https://vulners
.com/packetstorm/PACKETSTORM:85018 *EXPLOIT*
| PACKETSTORM:82197 5.0 https://vulners
.com/packetstorm/PACKETSTORM:82197 *EXPLOIT*
| PACKETSTORM:181059 5.0 https://vulners
.com/packetstorm/PACKETSTORM:181059 *EXPLOIT*
| PACKETSTORM:105672 5.0 https://vulners
.com/packetstorm/PACKETSTORM:105672 *EXPLOIT*
| PACKETSTORM:105591 5.0 https://vulners
.com/packetstorm/PACKETSTORM:105591 *EXPLOIT*
| MSF:AUXILIARY-SCANNER-HTTP-REWRITE_PROXY_BYPASS
5.0 https://vulners.com/metasploit/MSF:AUXI
LIARY-SCANNER-HTTP-REWRITE_PROXY_BYPASS- *EXPLOI
T*
| HTTPD:7B789993A3BDA0E4D014A8671E97D1EA 5.0 h
https://vulners.com/httpd/HTTPD:7B789993A3BDA0E4D014A867
1E97D1EA
| HTTPD:251E9EE30116844024950699040C983B 5.0 h
https://vulners.com/httpd/HTTPD:251E9EE30116844024950699
040C983B
| EXPLOITPACK:460143F0ACAE117DD79BD75EDFDA154B 5
https://vulners.com/exploitpack/EXPLOITPACK:460
143F0ACAE117DD79BD75EDFDA154B *EXPLOIT*
| EXPLOITPACK:44DAC602FB30402C58970DFAB1C4AF87 5
https://vulners.com/exploitpack/EXPLOITPACK:44D
AC602FB30402C58970DFAB1C4AF87 *EXPLOIT*
| EDB-ID:9887 5.0 https://vulners.com/exp
loitdb/EDB-ID:9887 *EXPLOIT*
| EDB-ID:17969 5.0 https://vulners.com/exp
loitdb/EDB-ID:17969 *EXPLOIT*
| CVE-2011-3368 5.0 https://vulners.com/cve
/CVE-2011-3368
| CVE-2007-6750 5.0 https://vulners.com/cve
/CVE-2007-6750
| CVE-2004-0263 5.0 https://vulners.com/cve
/CVE-2004-0263
| CVE-2003-0020 5.0 https://vulners.com/cve
/CVE-2003-0020
| CVE-2001-1556 5.0 https://vulners.com/cve
/CVE-2001-1556
| SSV:2174 4.7 https://vulners.com/see
bug/SSV:2174 *EXPLOIT*
| HTTPD:B63CF0157386C00B8FF9E943DA8F9A2F 4.7 h
https://vulners.com/httpd/HTTPD:B63CF0157386C00B8FF9E943
DA8F9A2F
| CVE-2007-3304 4.7 https://vulners.com/cve
/CVE-2007-3304
| SSV:71772 4.3 https://vulners.com/see
bug/SSV:71772 *EXPLOIT*
| SSV:2818 4.3 https://vulners.com/see
bug/SSV:2818 *EXPLOIT*
| SSV:2801 4.3 https://vulners.com/see
bug/SSV:2801 *EXPLOIT*
```



DO NOT COPY

```
| SSV:24250 4.3 https://vulners.com/see
bug/SSV:24250 *EXPLOIT*
| PACKETSTORM:61420 4.3 https://vulners
.com/packetstorm/PACKETSTORM:61420 *EXPLOIT*
| PACKETSTORM:102234 4.3 https://vulners
.com/packetstorm/PACKETSTORM:102234 *EXPLOIT*
| HTTPD:BE276450B6181A981775FFC94F438B18 4.3 h
https://vulners.com/httpd/HTTPD:BE276450B6181A981775FFC9
4F438B18
| HTTPD:99DE1CD158F65B4CFEA650CE55560C45 4.3 h
https://vulners.com/httpd/HTTPD:99DE1CD158F65B4CFEA650CE
55560C45
| HTTPD:5BBBCCFAA0C8B536B2CC3DA9DE0736F0 4.3 h
https://vulners.com/httpd/HTTPD:5BBBCCFAA0C8B536B2CC3DA9
DE0736F0
| HTTPD:4552C39F6C7671DAFFFFF7180F10B92D 4.3 h
https://vulners.com/httpd/HTTPD:4552C39F6C7671DAFFFFF718
0F10B92D
| HTTPD:44908D5C4721DCB28E9FB7C9E680D98A 4.3 h
https://vulners.com/httpd/HTTPD:44908D5C4721DCB28E9FB7C9
E680D98A
| EXPLOITPACK:683C3B1D02827D6B32706DB1D146B2D8 4
.3 https://vulners.com/exploitpack/EXPLOITPACK:683
C3B1D02827D6B32706DB1D146B2D8 *EXPLOIT*
| EDB-ID:17303 4.3 https://vulners.com/exp
loitdb/EDB-ID:17303 *EXPLOIT*
| CVE-2011-4317 4.3 https://vulners.com/cve
/CVE-2011-4317
| CVE-2007-6388 4.3 https://vulners.com/cve
/CVE-2007-6388
| CVE-2007-5000 4.3 https://vulners.com/cve
/CVE-2007-5000
| CVE-2006-5752 4.3 https://vulners.com/cve
/CVE-2006-5752
| CVE-2006-3918 4.3 https://vulners.com/cve
/CVE-2006-3918
| CVE-2005-3352 4.3 https://vulners.com/cve
/CVE-2005-3352
| 1337DAY-ID-9952 0.0 https://vulners.com/zdt
/1337DAY-ID-9952 *EXPLOIT*
| 1337DAY-ID-6193 0.0 https://vulners.com/zdt
/1337DAY-ID-6193 *EXPLOIT*
| 1337DAY-ID-16843 0.0 https://vulners
.com/zdt/1337DAY-ID-16843 *EXPLOIT*
| 1337DAY-ID-16323 0.0 https://vulners
.com/zdt/1337DAY-ID-16323 *EXPLOIT*
3306/tcp open mysql MySQL 4.1.7-standard
```

```
| vulners:
| cpe:/a:mysql:mysql:4.1.7-standard:
| CVE-2007-2691 4.9 https://vulners.com/cve
/CVE-2007-2691
| SSV:3280 4.6 https://vulners.com/see
bug/SSV:3280 *EXPLOIT*
| CVE-2008-2079 4.6 https://vulners.com/cve
/CVE-2008-2079
MAC Address: 00:0C:29:D5:B1:AD (VMware)

Service detection performed. Please report any incorrec
t results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 18.64 se
conds
```

